Projet ECOTrack

Bloc A1 – Planifier et organiser un projet

Groupe 2 : Yousra, Deborah, Nayel et Antoine

Table des matières

1.Introduction 3
1.1 Contexte de projet ECOTrack 3
1.2 Problématique Actuelle 3
1.3 Objectifs du Projet 4
2.Étude de faisabilité 4
2.1 Faisabilité technique 4
2.2 Faisabilité économique 6
2.3 Faisabilité opérationnelle 9
2.4 Conclusion et recommandations 11
3. Veille technologique 14
3.1 Méthodologie de veille technologique 14
3.2 Comparaison des technologies 16
3.3 Tendances et innovations 2025 18
3.4 Choix technologiques finaux pour ecotrack 19
3.5 Plan de veille continue 21
4.Architecture logicielle 23
4.1 Vision globale de l'architecture 23
4.2 Architecture détaillée par filière 25
4.3 Scalabilité et performance 34
4.4 Sécurité et conformité 36
5.Modelisation 39
5.1 Modélisation BPMN 39
5.2 Conclusion 45
6.Planification agile 46
6.1 Choix de la méthodologie agile 46
6.2 Backlog produit 47
6.3 Planification par sprint 49
6.4 Outils de gestion 51
6.5 Indicateurs clés de performance (KPI) 51
6.6 Gestion des risques 52
6.7 Ressources et budget 54

6.8 Diagramme de gantt 55
6.9 Synthèses & amélioration 56
7 . Audit initial 58
7.1 Objectifs de l'audit initial 58
7.2 . Analyse swot 59
7.3 Identification des risques 60
7.4 Quick wins — actions rapides à fort impact 62
7.5 Recommandations stratégiques 64
7.6 Conclusion de l'audit 66

1.Introduction

1.1 Contexte de projet ECOTrack

Le projet ECOTRACK s'inscrit dans une démarche de modernisation urbaine visant à transformer la gestion des déchets d'une métropole de 500 000 habitants en un service intelligent et durable. Actuellement, la ville doit gérer un parc de 2 000 conteneurs connectés générant un volume massif de données, estimé à environ 180 millions de mesures par an. L'enjeu majeur est de passer d'une collecte subie à une gestion pilotée par la donnée, en intégrant des technologies IoT pour le suivi en temps réel et des algorithmes d'intelligence artificielle pour l'optimisation des ressources. Cette plateforme doit répondre à des impératifs de performance logicielle mais aussi à des exigences critiques de cybersécurité pour protéger l'infrastructure critique de la ville contre d'éventuelles cyberattaques.

L'objectif métier d'ECOTRACK est de créer un écosystème collaboratif où convergent les besoins des citoyens, des agents de collecte et des décideurs municipaux. Pour les gestionnaires, la solution doit offrir une visibilité totale sur l'état de remplissage des bacs afin de supprimer les passages inutiles et de prévenir les débordements qui nuisent à la salubrité publique. Pour les citoyens, l'application mobile vise à encourager l'engagement écoresponsable via des mécanismes de gamification. Techniquement, cela implique la mise en place d'une architecture réseau robuste et hautement disponible, capable d'absorber un flux constant de données MQTT tout en garantissant l'intégrité et la confidentialité des informations traitées dans un environnement multizones sécurisé.

1.2 Problématique Actuelle

Le système de gestion des déchets actuel de la métropole souffre de plusieurs lacunes critiques qui justifient la mise en œuvre d'ECOTRACK :

- **Collecte inefficace :** Les tournées de ramassage suivent des circuits fixes et préétablis, sans tenir compte du taux de remplissage réel des bacs, entraînant 30 à 40% de passages sur des conteneurs vides.
- **Débordements fréquents :** L'absence de monitoring en temps réel empêche d'anticiper les pics de remplissage dans les zones à forte densité, provoquant des nuisances visuelles et olfactives ainsi que des plaintes récurrentes des usagers.
- **Coûts opérationnels élevés :** L'inefficacité des trajets génère des dépenses excessives en carburant, une usure prématurée des véhicules de collecte et une mobilisation non optimisée de la main-d'œuvre.
- **Impact environnemental négatif :** Les kilomètres parcourus inutilement augmentent l'empreinte carbone de la ville et contribuent à la pollution atmosphérique urbaine.

- **Vulnérabilités de l'infrastructure :** Le manque de sécurisation des objets connectés expose la métropole à des risques de compromission des données et d'interruption de service.

1.3 Objectifs du Projet

Pour répondre à ces enjeux, le projet ECOTRACK se fixe les cibles stratégiques suivantes :

- **Optimisation financière :** Réduire les coûts opérationnels de collecte de 20% à 30% grâce à une meilleure allocation des ressources et à la réduction des distances parcourues.
- **Amélioration de la salubrité :** Éliminer quasi totalement les débordements de conteneurs en maintenant un taux d'incidents inférieur à 5% grâce aux alertes prédictives.
- **Excellence algorithmique :** Développer et intégrer des algorithmes de type "Travelling Salesman Problem" (TSP) et "2-opt" pour calculer quotidiennement les itinéraires de collecte les plus performants.
- **Pilotage par la donnée :** Fournir aux gestionnaires des tableaux de bord analytiques en temps réel pour une prise de décision basée sur des indicateurs précis (KPIs).
- **Sécurisation et Disponibilité :** Garantir un uptime de la plateforme supérieur à 99.5% et assurer une protection totale contre les intrusions grâce à une architecture réseau segmentée et surveillée.

2.Étude de faisabilité

2.1 Faisabilité technique

A. Architecture Réseau Multi-Zones

L'infrastructure sera segmentée en zones de confiance distinctes pour limiter la surface d'attaque :

- **DMZ (VLAN 10) :** Héberge les points d'entrée publics. Le reverse proxy Nginx y sera positionné pour terminer les flux TLS et masquer l'architecture interne.
- **LAN Applicatif (VLAN 20) :** Zone isolée contenant les serveurs de traitement (FastAPI), les bases de données PostgreSQL et les microservices. Aucun flux direct ne sera autorisé depuis l'extérieur vers cette zone.
- **Zone d'Administration (VLAN 30) :** Un réseau de management dédié pour l'accès SSH et les interfaces de supervision.

- **Zone IoT (VLAN 40) :** Un réseau entièrement isolé hébergeant le broker MQTT Mosquitto et les 2 000 capteurs ultrasoniques déployés sur la métropole. Toutes les communications entre les capteurs et le broker sont chiffrées via TLS 1.3 avec authentification par certificats clients, garantissant l'intégrité et la confidentialité des données remontées. Aucun flux direct ne sera autorisé depuis cette zone vers la base de données — les données transitent exclusivement via l'API Backend en zone LAN.
- **Accès Distant :** La maintenance s'effectuera via un VPN (OpenVPN ou WireGuard) avec une authentification à deux facteurs (2FA), garantissant que seuls les administrateurs autorisés accèdent aux ressources critiques.

B. Stack Sécurité : Protection et Détection

La sécurité repose sur une approche de défense en profondeur :

- **Pare-feu (pfSense) :** Utilisation de règles "Deny-by-Default". Seuls les ports strictement nécessaires (80/443, 8883 pour MQTT) seront ouverts.
- **IDS/IPS (Suricata) :** Analyse du trafic en temps réel pour détecter les signatures d'attaques connues (CVE) et les comportements anormaux, particulièrement sur le protocole MQTT souvent ciblé dans l'IoT.
- **SIEM (Wazuh) :** Centralisation des alertes de sécurité pour corréler les événements (ex: une tentative d'injection SQL couplée à un scan de ports) et permettre une réaction rapide du SOC.
- **WAF (ModSecurity) :** Protection spécifique de la couche applicative contre le Top 10 OWASP, filtrant les requêtes malveillantes avant qu'elles n'atteignent les serveurs web.

C. Monitoring et Supervision : Observabilité

Pour maintenir la performance face à 2000 conteneurs connectés, nous déployons une suite d'observabilité complète :

- **Métriques (Prometheus/Grafana) :** Collecte des données de santé des serveurs (CPU, RAM, Disque) et des conteneurs via cAdvisor. Les dashboards Grafana permettront une visualisation en temps réel de la charge système.
- **Gestion des Logs (Stack ELK) :** Elasticsearch indexera l'ensemble des logs systèmes et applicatifs. Kibana facilitera le debugging et l'investigation post-incident.
- **Alerting :** Configuration d'Alertmanager pour notifier les équipes techniques via SMS ou Email en moins de 5 minutes pour tout incident critique (saturation disque, arrêt de service).

D. Haute Disponibilité et Résilience

L'objectif de 99.5% de disponibilité impose une redondance à chaque niveau :

- **Répartition de charge :** Mise en œuvre de HAProxy en mode failover (actif/passif) avec une IP virtuelle (VIP) via Keepalived. Si le nœud primaire tombe, le trafic est basculé instantanément sur le nœud secondaire.
- **Persistance des données :** Réplication Master-Slave de PostgreSQL pour éviter toute perte de données en cas de panne matérielle.
- **Stratégie de sauvegarde 3-2-1 :** Automatisation des backups (3 copies sur 2 supports différents, dont 1 hors site) pour garantir la reprise d'activité (PCA/PRA) même en cas de sinistre majeur sur le datacenter principal.

Justification technique : Le choix de solutions Open Source (pfSense, Wazuh, ELK) permet une maîtrise totale du code source et une réduction des coûts de licence, tout en offrant des performances de niveau industriel. La segmentation par VLANs est ici la pierre angulaire de la faisabilité, car elle permet de contenir une éventuelle compromission d'un capteur IoT dans une zone isolée, protégeant ainsi le cœur du système d'information.

2.2 Faisabilité économique

L'analyse financière du projet ECOTRACK démontre que l'investissement initial dans une infrastructure robuste et sécurisée est largement compensé par les gains opérationnels réalisés sur la logistique de collecte des déchets.

A. Coûts de Développement (Année 1)

Le développement s'étale sur 5 mois (16 semaines de sprint effectif).

Poste de dépense	**Détails**	**Coût Estimé**
1. Ressources Humaines		**126 k€**
Product Owner (25%)	Pilotage métier	8 k€
Scrum Master (25%)	Agilité et coordination	8 k€

Poste de dépense	Détails	Coût Estimé
Développeurs/Experts (3x100%)	Fullstack / Data / Cyber	80 k€
Architecte Infrastructure (50%)	Design réseau et sécurité	15 k€
DevOps/SRE (50%)	CI/CD et Monitoring	15 k€
2. Infrastructure Dev		**5,5 k€**
Instances Cloud (3 VM)	t3.medium (AWS/Azure)	2,5 k€
RDS PostgreSQL	Instance managée	1,5 k€
Stockage & Bande passante	S3 100GB + Flux IoT	1,5 k€
3. Licences et Outils		**3,5 k€**
Jira / GitHub Enterprise	Collaboration et versioning	1,5 k€
Outils Cyber/Monitoring	Certificats SSL, licences pro	2 k€
TOTAL ANNÉE 1	**Investissement Initial**	**135 k€**

B. Coûts Récurrents (Années 2-3)

Le passage en production nécessite une infrastructure plus puissante (High Availability).

1. **Infrastructure Production :** 18 k€/an (Serveurs redondants, réplication BDD, WAF Cloudflare).
2. **Maintenance et Support :** 45 k€/an (Maintenance corrective, mises à jour de sécurité trimestrielles, support N2).
3. **Licences Récurrentes :** 5 k€/an (Renouvellement certificats, SaaS monitoring).

TOTAL PAR AN (Années 2-3) : 68 k€/an

C. TCO (Total Cost of Ownership) 3 ans

Le coût total de possession sur 3 ans permet de budgétiser l'ensemble du cycle de vie du projet :

- Année 1 (Développement & Setup) : 135 k€
- Année 2 (Exploitation) : 68 k€
- Année 3 (Exploitation) : 68 k€

TCO 3 ANS : 271 k€

D. Économies Estimées

Le projet ECOTRACK génère des économies directes sur les budgets de fonctionnement de la métropole :

- **Optimisation tournée :** Réduction de 25% des trajets (carburant + usure camions) = **85 k€/an**.
- **Réduction débordements :** Moins d'interventions d'urgence et de nettoyage manuel = **25 k€/an**.
- **Gains productivité :** Meilleure gestion des plannings agents = **20 k€/an**.
- **Réductions plaintes :** Baisse des coûts de gestion administrative des litiges = **10 k€/an**.

TOTAL ÉCONOMIES : 140 k€/an

E. Calcul du ROI

Pour évaluer la rentabilité, nous comparons les gains nets par rapport à l'investissement.

- **Investissement initial (CAPEX) :** 135 k€
- **Économies cumulées sur 3 ans :** 140 k€ x 3 = 420 k€
- **Coûts récurrents cumulés (2 ans OPEX) :** 68 k€ x 2 = 136 k€
- **Gain net à 3 ans :** (420 k€ - 136 k€) - 135 k€ = **149 k€**

ROI 3 ANS : 110 %

Seuil de rentabilité (Break-even point) : Atteint après **1,9 an**.

Justification de rentabilité : Le projet est hautement rentable dès la fin de la deuxième année. Au-delà de l'aspect financier, le ROI est renforcé par le bénéfice "image" pour la métropole et la réduction de l'empreinte carbone, objectifs prioritaires du cahier des charges. L'utilisation d'une stack technique Open Source (pfSense, ELK, Prometheus) permet de maintenir un TCO bas en évitant les coûts de licences propriétaires élevés.

2.3 Faisabilité opérationnelle

Cette section évalue la capacité de l'organisation à mener à bien le projet ECOTRACK en respectant les délais, les ressources humaines et les contraintes méthodologiques, tout en intégrant une culture de sécurité forte.

A. Organisation de l'Équipe Projet

L'équipe est dimensionnée pour couvrir l'ensemble du spectre technique, du développement applicatif à la sécurisation des infrastructures.

1. **Composition de l'Équipe :** 7 personnes (5.5 ETP).
2. **Répartition des Rôles :** Outre les rôles classiques (PO, SM, Dev), l'**Architecte** et le **DevOps/SRE** collaborent étroitement pour garantir que chaque brique déployée respecte la segmentation réseau (VLANs) et les politiques de sécurité (PSSI) définies en amont.

B. Méthodologie de Gestion de Projet

Nous adoptons la méthodologie **Scrum** pour sa flexibilité et sa capacité à intégrer des tests de sécurité itératifs.

- **Sprints :** 2 semaines.
- **Outils :** Jira pour le suivi des tickets, GitHub pour le versioning avec intégration de scans de vulnérabilités (SAST/DAST) dans la CI/CD.
- **Approche DevSecOps :** La sécurité n'est pas une étape finale, mais une composante de chaque "Definition of Done" (DoD).

C. Planning Prévisionnel (Focus Infrastructure & Sécurité)

Le planning de 16 semaines est divisé en deux phases majeures :

- **Phase 1 (S1-S4) : Socle technique et Sécurisation**
    - **Sprint 1 :** Mise en place de l'hyperviseur, des VLANs et du Firewall pfSense.
    - **Sprint 2 :** Configuration du broker MQTT sécurisé (TLS) et de l'ingestion des flux.
    - **Sprint 3 :** Déploiement du SIEM (Wazuh) et du Reverse Proxy (Nginx + ModSecurity).
    - **Sprint 4 :** Durcissement (Hardening) des OS et mise en place du bastion d'administration.
- **Phase 2 (S5-S8) : Optimisation et Mise en Production**

- **Sprint 5 :** Intégration des algorithmes d'optimisation et monitoring des performances.
- **Sprint 6 :** Finalisation des dashboards Grafana et alertes critiques.
- **Sprint 7 :** Tests d'intrusion (Pentest) et audits de configuration.
- **Sprint 8 :** Correction des failles identifiées, Plan de Continuité d'Activité (PCA) et bascule en production.

D. Risques Opérationnels

En plus des risques généraux, voici les risques spécifiques à la filière **Cyber & Réseaux** :

1. **Départ membre clé (Prob: Faible, Impact: Élevé)**
   - *Mitigation :* Documentation systématique des configurations (Wiki/Confluence), rotation des secrets et binômage sur les tâches d'administration critique.
2. **Retard développement fonctionnalité critique (Prob: Moyenne, Impact: Élevé)**
   - *Mitigation :* Priorisation MoSCoW (Must-have : sécurité et ingestion ; Nice-to-have : application mobile).
3. **Résistance utilisateurs finaux (Prob: Moyenne, Impact: Moyen)**
   - *Mitigation :* Ateliers de sensibilisation à la cybersécurité et aux nouveaux outils de bord.
4. **Indisponibilité de l'infrastructure Cloud/Datacenter (Prob: Faible, Impact: Critique)**
   - *Mitigation :* Architecture Multi-AZ (Zones de disponibilité) et mise en place d'un Plan de Reprise d'Activité (PRA) testé au Sprint 8.
5. **Compromission d'un accès administrateur (Prob: Faible, Impact: Critique)**
   - *Mitigation :* Authentification Multi-Facteurs (MFA) obligatoire, principe de moindre privilège et journalisation stricte des accès SSH/VPN.
6. **Saturation réseau par déni de service (DoS) sur l'IoT (Prob: Moyenne, Impact: Élevé)**
   - *Mitigation :* Limitation de débit (Rate limiting) au niveau du firewall et implémentation de Suricata pour détecter les patterns de flood MQTT.
7. **Non-conformité RGPD (Prob: Faible, Impact: Moyen)**
   - *Mitigation :* Registre de traitement des données, anonymisation des logs et purge automatique des données de géolocalisation après 1 an.

E. Facteurs Clés de Succès

Pour garantir la réussite du projet ECOTRACK et la livraison d'une infrastructure résiliente, plusieurs facteurs organisationnels et stratégiques ont été identifiés :

- **Engagement fort du sponsor projet :** Le soutien du Directeur de la Gestion des Déchets assure l'alignement stratégique et facilite le déblocage des ressources budgétaires ou matérielles.
- **Équipe multidisciplinaire expérimentée :** La complémentarité entre les profils Cyber-Réseaux et Développeurs permet d'appliquer les principes du *Privacy by Design* dès les premières lignes de code.
- **Maîtrise de la Méthodologie Agile :** L'utilisation de Scrum permet une visibilité constante sur l'avancement et une correction rapide des dérives de périmètre.
- **Implication des utilisateurs finaux dès le Sprint 2 :** L'intégration des chauffeurs et agents de tri dans les boucles de feedback garantit que l'outil répond à une réalité terrain et favorise l'adoption future.
- **Architecture scalable et sécurisée :** Le choix de la containerisation et de la segmentation réseau (VLANs) permet de faire évoluer la plateforme (passage de 2 000 à 10 000 capteurs) sans compromettre la sécurité.
- **Validation et tests continus :** L'automatisation des tests fonctionnels et des scans de vulnérabilités dans la CI/CD réduit drastiquement le risque de régressions ou de failles critiques en production.
- **Communication transparente :** Des rapports de sprint réguliers et une gestion proactive des risques permettent de maintenir une confiance totale avec toutes les parties prenantes.

2.4 Conclusion et recommandations

A. Synthèse de la Faisabilité

DÉCISION : GO

- **Faisabilité Technique : FAVORABLE**
    - L’utilisation d’une stack open-source mature (pfSense, Suricata, ELK) et d’une architecture multi-zones par VLANs permet de répondre aux exigences de sécurité et de montée en charge du projet. Les risques techniques sont maîtrisés grâce à la segmentation et à la haute disponibilité.
- **Faisabilité Économique : FAVORABLE**

- Le projet présente un ROI de 110 % sur 3 ans avec un seuil de rentabilité atteint en moins de 2 ans. Les économies de carburant et l'optimisation des ressources humaines justifient largement l'investissement initial.

- **Faisabilité Opérationnelle : FAVORABLE**
  - L'équipe projet dispose des compétences nécessaires pour couvrir tout le cycle DevSecOps. La méthodologie Scrum garantit un contrôle continu des risques et une adaptation aux besoins réels du terrain.

Conclusion Globale : Le projet ECOTRACK est non seulement viable, mais essentiel pour la modernisation de la gestion des déchets de la métropole. L'analyse démontre que les bénéfices financiers, environnementaux et sociaux surpassent largement les coûts de mise en œuvre. L'infrastructure réseau et sécurité proposée offre un socle robuste capable d'évoluer avec l'augmentation du nombre de capteurs IoT.

Toutefois, une attention particulière devra être portée à l'intégration des flux de données massifs (180M de mesures/an) pour éviter toute saturation des outils de monitoring. La réussite dépendra de la rigueur appliquée lors du déploiement du pare-feu et de la capacité à former les agents aux nouveaux outils numériques. En conclusion, ECOTRACK présente toutes les garanties pour être un succès technologique et économique.

B. Recommandations Stratégiques

1. **Approche MVP (Minimum Viable Product)**
   - Lancer avec les fonctionnalités essentielles : ingestion MQTT sécurisée, cartographie temps réel et alertes de débordement.
   - Itérer rapidement pour ajouter les algorithmes d’optimisation complexes une fois le socle stable.
2. **Implication Continue des Utilisateurs Finaux**
   - Organiser des sessions de Beta testing dès le Sprint 4 avec un échantillon de 10 chauffeurs pilotes pour valider l'ergonomie de l'interface et la pertinence des alertes.
3. **Architecture Scalable et Résiliente**
   - Adopter une approche "Design for Failure" : tester les mécanismes de failover (HAProxy/Keepalived) dès le Sprint 3 pour garantir la continuité de service en cas de panne matérielle.
4. **Sécurité et Conformité RGPD Natives**

- Appliquer le *Privacy by Design* : chiffrer les données sensibles (géolocalisation des agents) et prévoir un audit de configuration (Pentest interne) avant toute exposition publique.

5. **Documentation Technique et Opérationnelle**
    - Maintenir des *Runbooks* à jour pour les équipes d'exploitation, décrivant les procédures à suivre en cas d'alerte de sécurité ou d'incident réseau majeur.
6. **Automatisation de la Qualité et de la Sécurité**
    - Intégrer des scans de vulnérabilités automatiques dans la CI/CD et viser une couverture de tests supérieure à 80% pour sécuriser les mises à jour futures.
7. **Pilotage par la Donnée (KPIs)**
    - Mettre en place un reporting hebdomadaire aux sponsors basés sur les métriques réelles de la plateforme (uptime, taux de détection IDS, économies de trajets estimées).

3. Veille technologique

3.1 Méthodologie de veille technologique

La réussite du projet ECOTRACK repose sur l'intégration de technologies à la fois innovantes et éprouvées. Pour garantir la pertinence de nos choix techniques, j'ai mis en place une méthodologie de veille structurée axée sur trois piliers : la sécurité offensive/défensive, les protocoles IoT et la résilience des infrastructures. Cette démarche permet non seulement d'anticiper les vulnérabilités émergentes (0-day) sur les composants de notre stack (pfSense, Suricata, MQTT), mais aussi d'identifier les meilleures pratiques en matière d'optimisation réseau et de réduction de l'empreinte carbone numérique. L'objectif est de transformer ce flux d'informations en décisions architecturales concrètes pour assurer la pérennité du système sur les trois prochaines années.

Pour documenter cette veille, j'utilise un système de curation basé sur la méthode Zettelkasten via Obsidian, permettant de lier les nouvelles vulnérabilités identifiées aux composants spécifiques de notre architecture. Chaque information est filtrée selon trois critères : la maturité de la technologie (LTS vs Bêta), sa compatibilité avec l'écosystème open-source existant et son impact sur la conformité RGPD. Cette organisation permet de passer d'une simple lecture passive à une analyse proactive, où chaque "alerte" peut donner lieu à l'ouverture d'un ticket dans notre backlog de sécurité ou à une modification de notre politique de filtrage sur le pare-feu.

A. Sources Consultées

Sources Techniques :

- **GitHub Trending :** Identification de nouveaux plugins pour la stack ELK ou de scripts de durcissement (hardening) pour nos VM Linux.
- **CVE Details & NVD (NIST) :** Surveillance quotidienne des nouvelles vulnérabilités affectant nos services (Nginx, PostgreSQL, Mosquitto).
- **Medium/Dev.to :** Retours d'expérience sur le déploiement de SIEM open-source en environnement haute disponibilité.
- **Documentation officielle :** Suivi des changelogs de pfSense, Suricata et des spécifications OASIS pour le protocole MQTT.

Conférences et Événements :

- **Conférences Cyber :** Analyse des rapports de la Black Hat et du FIC (Forum International de la Cybersécurité) pour les menaces liées aux Smart Cities.
- **Webinars Cloud :** Sessions techniques AWS/Azure sur la sécurisation des passerelles IoT (IoT Gateways).

- **Meetups locaux :** Participation aux événements OWASP Paris pour les problématiques de sécurité applicative (WAF).

Veille Réglementaire :

- **ANSSI :** Application des guides de durcissement (système, réseau, virtualisation) et notes d'alerte du CERT-FR.
- **CNIL :** Suivi des recommandations sur la sécurisation des données de géolocalisation et le principe de minimisation.
- **OWASP :** Référence constante au Top 10 pour la configuration de ModSecurity.

B. Outils Utilisés

- **Feedly :** Agrégation de plus de 50 flux RSS (ThreatPost, BleepingComputer, Krebs on Security).
- **Google Alerts :** Mots-clés ciblés tels que "MQTT vulnerability", "Smart City Cyber Attack" et "pfSense optimization".
- **Twitter/X :** Suivi de chercheurs en sécurité et de comptes officiels (CERT-FR, Kali Linux, Offensive Security).
- **Reddit :** Communautés spécialisées comme r/netsec, r/pfsense et r/iotsecurity pour les retours communautaires.
- **Obsidian :** Base de connaissances personnelle pour structurer et lier les découvertes technologiques.

C. Fréquence et Organisation

- **Veille quotidienne (15-30 min) :** Scan rapide des alertes de sécurité critiques (CERT-FR) et des flux RSS pour identifier les urgences.
- **Veille hebdomadaire (2h) :** Analyse approfondie d'une technologie ou d'une vulnérabilité complexe pour évaluer son impact sur ECOTRACK.
- **Revue mensuelle :** Synthèse des tendances (ex: adoption du Zero Trust ou du protocole TLS 1.3) pour ajuster la roadmap technique.
- **Partage équipe :** Présentation trimestrielle des évolutions majeures pouvant impacter la maintenance ou la sécurité du projet.

3.2 Comparaison des technologies

L'infrastructure d'ECOTRACK nécessite des outils capables de traiter un volume massif de données (180M de mesures/an) tout en garantissant une détection des menaces en temps réel. Voici l'analyse comparative des solutions pressenties.

A. SIEM : Centralisation et corrélation des logs

Le SIEM est le cœur de notre visibilité sécuritaire. Nous comparons ici **Wazuh** (orienté protection des endpoints), **Splunk** (leader du marché) et la **Stack ELK** (standard pour les logs).

Critères (Pondérés)	**Wazuh**	**Splunk**	**ELK Stack**
Détection (Règles/Alertes)	9/10	10/10	6/10
Coût (Licences/Infra)	9/10	2/10	7/10
Scalabilité (Volumes logs)	7/10	9/10	9/10
Intégrations (API/Systèmes)	8/10	10/10	8/10
Conformité (ANSSI/RGPD)	9/10	9/10	7/10
TOTAL /50	**42/50**	**40/50**	**37/50**

CHOIX RECOMMANDÉ : WAZUH

Justification : Pour ECOTRACK, Wazuh est le choix le plus rationnel. Contrairement à Splunk (extrêmement coûteux au volume de logs) ou ELK (qui nécessite une configuration manuelle complexe pour la sécurité), Wazuh offre nativement des règles de détection conformes aux exigences de l'ANSSI et une intégration parfaite avec les agents légers sur nos serveurs.

B. IDS/IPS : Analyse de trafic en temps réel

L'IDS doit analyser les flux MQTT et HTTP sans ralentir le réseau.

Critères	**Suricata**	**Snort 3**	**Zeek (Bro)**
Performance (Multi-threading)	10/10	8/10	7/10

Critères	Suricata	Snort 3	Zeek (Bro)
Règles (Qualité/Quantité)	9/10	9/10	6/10
Protocoles supportés	9/10	8/10	10/10
Communauté/Support	9/10	10/10	7/10
Facilité d'intégration	9/10	7/10	6/10
TOTAL /50	**46/50**	**42/50**	**36/50**

CHOIX RECOMMANDÉ : SURICATA *Justification :* Suricata excelle grâce à son support natif du multi-threading, indispensable pour traiter les 180 millions de mesures annuelles sans perte de paquets. Sa capacité à inspecter les flux TLS et son intégration native dans pfSense en font l'outil idéal pour ECOTRACK.

C. Firewall : Segmentation et filtrage périmétrique

Le firewall doit gérer la segmentation en 3 zones (DMZ, LAN, Admin) et les accès VPN.

Critères	pfSense	FortiGate	Cisco ASA
Performance / Débit	8/10	10/10	9/10
Fonctionnalités (VPN/IDS)	9/10	10/10	8/10
Facilité de configuration	9/10	7/10	5/10
Coût (TCO 3 ans)	10/10	4/10	5/10
Support Technique	7/10	9/10	9/10
TOTAL /50	**43/50**	**40/50**	**36/50**

CHOIX RECOMMANDÉ : PFSENSE

Justification : Bien que FortiGate offre des performances matérielles supérieures (ASIC), pfSense est largement suffisant pour le débit de données IoT d'ECOTRACK. Sa gratuité logicielle permet de réallouer le budget sur le durcissement de l'infrastructure, tout en offrant une interface de gestion des VLANs et du VPN (OpenVPN/WireGuard) très intuitive pour l'équipe projet.

3.3 Tendances et innovations 2025

L'année 2025 marque un tournant dans la gestion des infrastructures critiques. Pour ECOTRACK, l'adoption de ces tendances n'est pas seulement un gage de modernité, mais une nécessité pour garantir la résilience face à des cybermenaces de plus en plus sophistiquées.

A. Tendances Globales

1. **IA Générative et LLMs : Assistance et Analyse Opérationnelle**
    - **Impact :** Automatisation du support technique et aide à la décision pour les agents de terrain.
    - **Application ECOTRACK :** Implémentation d'un assistant intelligent pour les chauffeurs, capable de résumer les anomalies de tournée en langage naturel et de générer des rapports de maintenance automatisés à partir des logs de capteurs.
2. **Edge Computing et IoT : Intelligence à la source**
    - **Impact :** Réduction drastique de la bande passante consommée et de la latence de détection.
    - **Application ECOTRACK :** Utilisation de micro-modèles de Machine Learning (TensorFlow Lite) directement sur les passerelles IoT pour filtrer les "fausses" mesures de remplissage (ex : secousses) avant l'envoi au serveur central via MQTT 5.0.
3. **Zero Trust Architecture (ZTA) : "Never Trust, Always Verify"**
    - **Impact :** Suppression de la confiance implicite accordée aux terminaux connectés au réseau interne.
    - **Application ECOTRACK :** Mise en place d'une micro-segmentation stricte où chaque capteur et chaque terminal de chauffeur doit s'authentifier de manière continue pour accéder aux APIs, limitant ainsi les déplacements latéraux en cas de compromission.

B. Tendances Spécifiques : Cyber-Réseaux

En tant qu'experts en infrastructure, nous devons intégrer ces quatre innovations majeures pour sécuriser durablement la métropole :

1. **SASE (Secure Access Service Edge) : Convergence Réseau et Sécurité**
    - **Impact :** Unification des services de sécurité (VPN, Firewall, filtrage web) dans une architecture distribuée.
    - *Application ECOTRACK :* Simplification de l'accès distant pour les techniciens de maintenance via une solution SASE, garantissant la même politique de sécurité qu'ils soient sur site ou en intervention 4G/5G.
2. **XDR (Extended Detection & Response) : Visibilité Holistique**
    - **Impact :** Corrélation des menaces au-delà du simple réseau, incluant les endpoints, les identités et le cloud.
    - *Application ECOTRACK :* Utilisation de Wazuh pour corréler les tentatives de brute-force sur l'interface web avec des flux réseau suspects détectés par Suricata, permettant une réponse automatisée (blocage IP) en moins de 2 minutes.
3. **Infrastructure as Code Security (IaC Security)**
    - **Impact :** Sécurisation de l'infrastructure dès sa définition logicielle (Terraform, Ansible).
    - *Application ECOTRACK :* Intégration d'outils comme Checkov dans la CI/CD pour scanner les fichiers de configuration de nos VM et de pfSense, évitant ainsi l'ouverture accidentelle de ports ou des configurations par défaut vulnérables.
4. **Quantum-Safe Cryptography : Anticipation Post-Quantique**
    - **Impact :** Transition vers des algorithmes de chiffrement résistants à la puissance de calcul des futurs ordinateurs quantiques.
    - *Application ECOTRACK :* Migration prioritaire vers TLS 1.3 avec des suites de chiffrement à base de courbes elliptiques robustes (Ed25519) pour protéger les données de la métropole contre les attaques de type "Store Now, Decrypt Later".

3.4 Choix technologiques finaux pour Ecotrack

Sur la base des analyses comparatives effectuées et des tendances 2025 identifiées (Zero Trust, XDR, Automatisation), voici les choix technologiques retenus pour l'infrastructure sécurisée d'ECOTRACK.

A. Synthèse des Choix par Composant

COMPOSANT: PARE-FEU ET SEGMENTATION RÉSEAU TECHNOLOGIE RETENUE : pfSense SCORE COMPARATIF : 43/50 JUSTIFICATION :

1. **Coût et Efficacité :** Solution Open Source permettant d'investir le budget économisé sur les licences (type Fortinet) dans la redondance matérielle.
2. **Gestion des VLANs :** Capacités natives de segmentation ultra-performantes pour isoler les 3 zones critiques (DMZ, LAN, ADMIN).
3. **Écosystème Intégré :** Permet l'installation directe de packages comme Suricata et HAProxy, centralisant l'administration. **RISQUES :** Support communautaire uniquement. *Mitigation :* Documentation rigoureuse et mise en place d'un cluster HA (Haute Disponibilité) pour éviter tout Single Point of Failure.

COMPOSANT: DÉTECTION D'INTRUSION (IDS/IPS) TECHNOLOGIE RETENUE : Suricata SCORE COMPARATIF : 46/50 JUSTIFICATION :

1. **Performance Multi-thread :** Capable d'analyser les flux massifs des 2000 capteurs IoT sans latence réseau.
2. **Analyse de Protocole :** Support avancé du protocole MQTT, essentiel pour détecter les injections ou malformations de paquets IoT.
3. **Interopérabilité :** Format de logs standard (EVE JSON) facilitant l'ingestion automatique vers Wazuh et ELK. **RISQUES :** Consommation CPU élevée sur de l'analyse SSL profonde. *Mitigation :* Déchargement (Offloading) du chiffrement TLS sur le reverse proxy Nginx avant analyse.

COMPOSANT : SIEM ET SÉCURITÉ DES ENDPOINTS TECHNOLOGIE RETENUE : Wazuh

SCORE COMPARATIF : 42/50 JUSTIFICATION :

1. **Conformité pré-intégrée :** Inclut des dashboards conformes RGPD et des modules de vérification de politique de sécurité (SCA).
2. **Réponse Active :** Capacité à exécuter des scripts de blocage automatique dès qu'une menace est détectée (ex: ban IP après force-brute).
3. **Légèreté :** Agents peu gourmands en ressources, idéal pour nos serveurs virtualisés. **RISQUES :** Courbe d'apprentissage sur la création de règles personnalisées. *Mitigation :* Utilisation des bases de règles communautaires et formation interne.

B. Stack Technique Complète Recommandée

Voici la synthèse de l'architecture "Secure by Design" pour ECOTRACK :

- **Virtualisation :** Proxmox VE (Gestion des VM et conteneurs LXC).
- **Infrastructure Réseau :** pfSense (Firewalling, VPN WireGuard, VLANs).
- **Systèmes d'Exploitation :** Debian 12 (Hardened) pour les serveurs applicatifs.
- **Base de Données :** PostgreSQL avec extension PostGIS (Données géographiques) et réplication Master-Slave.
- **Ingestion de Données :** Mosquitto (Broker MQTT) sécurisé par TLS 1.3.
- **Monitoring & Métriques :** Prometheus + Grafana (Dashboarding temps réel).
- **Gestion des Logs & SIEM :** Wazuh couplé à une instance Elasticsearch (Stockage long terme).
- **Sécurité Applicative :** Nginx Reverse Proxy + ModSecurity (WAF).
- **CI/CD :** GitHub Actions avec intégration de Trivy (Scan de conteneurs) et Ansible pour le déploiement automatisé des configurations de sécurité.

3.5 Plan de veille continue

A. Pendant le Projet (16 semaines)

- **Veille hebdomadaire (2h) :** Analyse approfondie centrée sur les composants actifs de la stack ECOTRACK — suivi des changelogs de pfSense, Suricata et Wazuh, et évaluation de l'impact de toute nouvelle CVE publiée sur NVD/NIST sur notre configuration en cours.
- **Sprint Review :** À chaque fin de sprint, partage des découvertes ayant eu un impact concret sur l'architecture — modification d'une règle Suricata, mise à jour d'une image Docker suite à une vulnérabilité, ajustement d'une politique pfSense.
- **Tech Watch mensuelle :** Présentation à l'équipe d'une tendance identifiée pendant la veille — par exemple l'évolution des recommandations ANSSI sur le Zero Trust ou les nouvelles techniques d'attaque sur les infrastructures IoT publiées post-Black Hat.
- **Alertes critiques immédiates :** Tout CVE de sévérité CVSS ≥ 8.0 affectant un composant de notre stack (Nginx, Mosquitto, PostgreSQL, OpenSSL) déclenche une notification immédiate à l'équipe via le canal dédié, sans attendre la prochaine réunion planifiée.

B. Post-Déploiement (Maintenance)

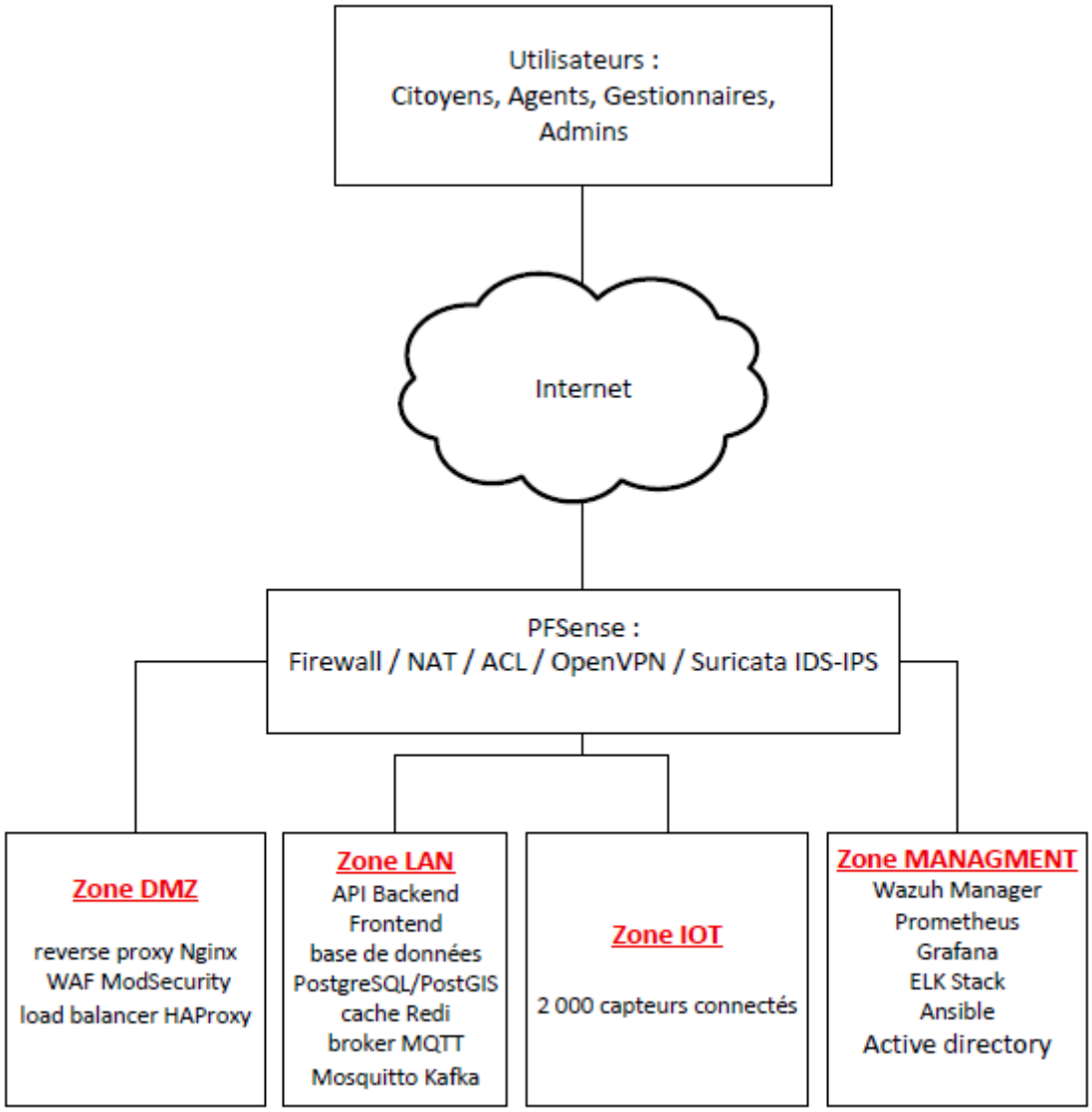
- **Monitoring des versions :** Intégration de Trivy dans la CI/CD GitHub Actions pour scanner automatiquement les images Docker à chaque build et bloquer tout déploiement contenant une CVE critique non corrigée.
- **Veille sécurité :** Maintien des flux Feedly et Google Alerts configurés en section I (mots-clés : *"MQTT vulnerability"*, *"pfSense CVE"*, *"Smart City Cyber Attack"*) pour assurer une surveillance continue des menaces ciblant notre stack.
- **Roadmaps officielles :** Suivi des évolutions majeures de pfSense CE, Suricata et Wazuh pour anticiper les migrations de version et maintenir la cohérence de l'infrastructure sur le long terme.
- **Participation communauté :** Veille active sur r/netsec, r/pfsense et r/iotsecurity ainsi que participation aux événements OWASP Paris pour maintenir le niveau de compétence de l'équipe et rester en phase avec les pratiques du terrain.

C. Ressources Recommandées

- **Newsletters :** SANS NewsBites (synthèse bihebdomadaire des incidents majeurs), bulletins CERT-FR (alertes sur nos composants), ANSSI (guides de durcissement mis à jour).
- **Podcasts :** Darknet Diaries (analyse d'incidents de sécurité réels en infrastructure), No Limit Secu (équivalent francophone orienté pratique professionnelle).
- **YouTube :** NetworkChuck (tutoriels pratiques pfSense, WireGuard, VLANs), John Hammond (analyses de vulnérabilités et CTF write-ups utiles pour affiner les règles Suricata).
- **Formation continue :** TryHackMe / HackTheBox pour la pratique offensive/défensive en environnement contrôlé, et certifications cibles : CompTIA Security+ (court terme), PCNSA pfSense (moyen terme)

4.Architecture logicielle

4.1 Vision globale de l'architecture



Ce schéma présente la vue d'ensemble de la plateforme ECOTRACK : les 4 zones réseau (DMZ, LAN, IoT, Management), le firewall pfSense central, et les composants principaux dans chaque zone. Il illustre comment les utilisateurs accèdent à la plateforme via la DMZ et comment les 2 000 capteurs IoT remontent leurs données vers le LAN.

La plateforme ECOTRACK repose sur une architecture réseau segmentée en quatre zones de sécurité isolées, conçue selon le principe de défense en profondeur. Cette approche garantit qu'aucune compromission d'une zone ne puisse se propager directement aux autres, limitant ainsi les mouvements latéraux en cas d'intrusion. L'ensemble de l'infrastructure est orchestré autour d'un firewall central pfSense qui filtre et contrôle l'intégralité des flux inter-zones,

depuis les requêtes des 15 000 utilisateurs jusqu'aux données remontées par les 2 000 capteurs IoT déployés sur la métropole.

L'architecture distingue quatre zones fonctionnelles complémentaires. La zone DMZ expose les services accessibles depuis Internet — reverse proxy Nginx, WAF ModSecurity et load balancer HAProxy— tout en protégeant le réseau interne. La zone LAN héberge les composants applicatifs sensibles, inaccessibles directement depuis Internet : API Backend, Frontend, base de données PostgreSQL/PostGIS, cache Redis, broker MQTT Mosquitto et Kafka. La zone IoT isole les 2 000 capteurs connectés dans un segment réseau dédié, empêchant tout accès direct à la base de données. Enfin, la zone Management centralise la supervision et la sécurité via Wazuh SIEM, Prometheus, Grafana, ELK Stack, Suricata IDS et Ansible, accessible uniquement via tunnel VPN avec authentification forte.

Cette segmentation répond directement aux exigences du cahier des charges : garantir une disponibilité de 99,5%, un temps de détection des incidents inférieur à 5 minutes et zéro incident de sécurité majeur. Chaque composant est dimensionné pour absorber un débit de 400 messages IoT par minute et supporter 500 utilisateurs simultanés, tout en maintenant un temps de réponse API inférieur à 500ms au 95ème percentile.

A. Principes Architecturaux

- Modularité : chaque composant de l'infrastructure est indépendant et déployé dans sa propre zone réseau. Un service peut être mis à jour ou remplacé sans impacter les autres zones.
- Scalabilité : l'architecture est conçue pour une montée en charge horizontale — ajout d'instances API derrière HAProxy, réplication PostgreSQL, partitionnement Kafka — sans refonte de l'infrastructure existante.
- Résilience : HAProxy en configuration actif/passif avec Keepalived assure la continuité de service. La stratégie de backup 3-2-1 garantit un RPO inférieur à 1 heure et un RTO inférieur à 4 heures.
- Sécurité : principe de défense en profondeur avec filtrage pfSense entre chaque zone, chiffrement TLS 1.3 obligatoire sur tous les flux exposés et communications MQTT sécurisées par certificats.
- Maintenabilité : l'ensemble des configurations est versionné et déployé via Ansible (Infrastructure as Code), garantissant la reproductibilité des environnements et la traçabilité des changements.

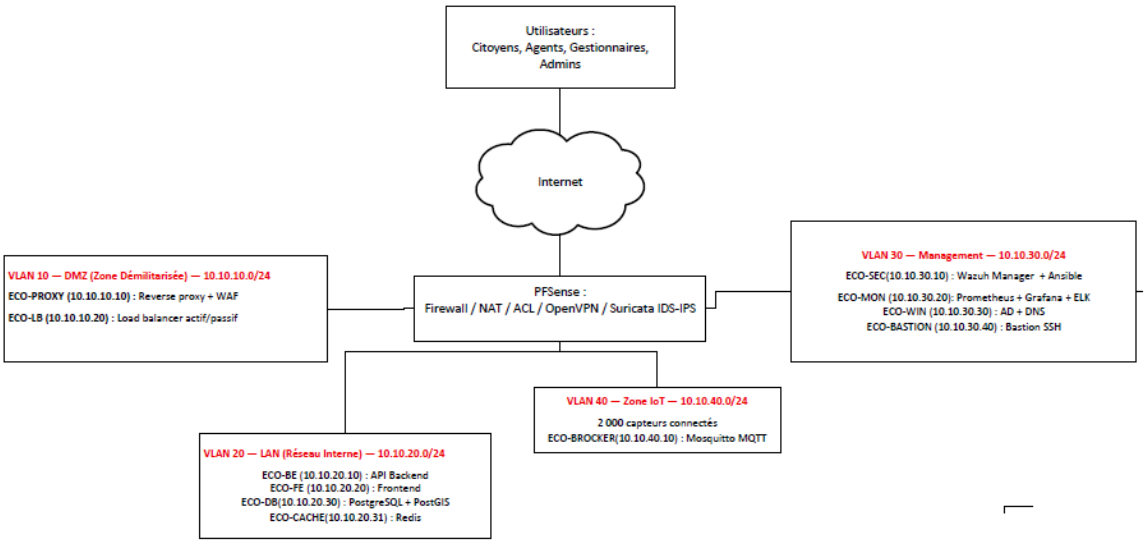
B. Vue d'Ensemble des Composants

- Couche Exposition (DMZ — 10.10.10.0/24) : HAProxy, Nginx + WAF ModSecurity — point d'entrée unique et contrôlé pour tous les flux entrants depuis Internet.

- Couche Applicative et Données (LAN — 10.10.20.0/24) : API Backend, Frontend, PostgreSQL + PostGIS, Redis, Mosquitto MQTT, Kafka — logique métier, persistance et transit des données, inaccessibles depuis Internet.
- Couche IoT (10.10.40.0/24) : 2 000 capteurs ultrasoniques et passerelles IoT — remontée des niveaux de remplissage toutes les 15 minutes via MQTT/TLS vers le broker Mosquitto.
- Couche Supervision (Management — 10.10.30.0/24) : Prometheus, Grafana, Wazuh SIEM, ELK Stack, Ansible — surveillance continue, centralisation des logs et réponse aux incidents.

4.2 Architecture détaillée par filière

A. Segmentation Réseau (VLANs)



Ce schéma détaille la topologie réseau d'ECOTRACK : les 4 VLANs (10.10.10.0/24, 10.10.20.0/24, 10.10.30.0/24 et 10.10.40.0/24), les adresses IP de chaque serveur, le firewall pfSense au centre,

L'infrastructure ECOTRACK est segmentée en quatre VLANs distincts, chacun correspondant à un niveau de confiance et d'exposition différent. Cette segmentation est appliquée au niveau du firewall pfSense qui constitue le point de contrôle central de tous les flux inter-zones. Aucun trafic ne peut transiter d'un VLAN à un autre sans passer par une règle de filtrage explicitement autorisée.

VLAN 10 — DMZ (Zone Démilitarisée) — 10.10.10.0/24

La DMZ constitue la seule zone exposée à Internet. Elle héberge les services frontaux de la plateforme : le reverse proxy Nginx associé au WAF ModSecurity et le load balancer HAProxy en configuration actif/passif. Tout trafic entrant depuis Internet est bloqué par défaut —

seuls les ports 80 (redirection vers 443) et 443 (HTTPS) sont ouverts explicitement. Les flux sortants de la DMZ vers le LAN sont strictement limités aux ports applicatifs nécessaires.

Composant	IP	Rôle
HAProxy	10.10.10.10	Load balancer actif/passif
Nginx + ModSecurity	10.10.10.20	Reverse proxy + WAF

VLAN 20 — LAN (Réseau Interne) — 10.10.20.0/24

Le LAN héberge l'ensemble des composants applicatifs et des données sensibles de la plateforme. Il n'est jamais accessible directement depuis Internet — tout accès transite obligatoirement par la DMZ. Les serveurs de ce VLAN communiquent entre eux sur des ports spécifiques et documentés, sans accès sortant vers Internet.

Composant	IP	Rôle
API Backend	10.10.20.10	Logique métier ECOTRACK
Frontend	10.10.20.20	Serveur fichiers statiques
PostgreSQL + PostGIS	10.10.20.30	Base de données principale
Redis	10.10.20.31	Cache et sessions

VLAN 30 — Management — 10.10.30.0/24

La zone Management héberge tous les outils de supervision et de sécurité. Elle dispose d'une visibilité en lecture sur l'ensemble des autres VLANs pour la collecte des métriques et des logs, mais aucun flux applicatif ne transite par elle. L'accès à cette zone est restreint au tunnel VPN avec authentification à double facteur obligatoire.

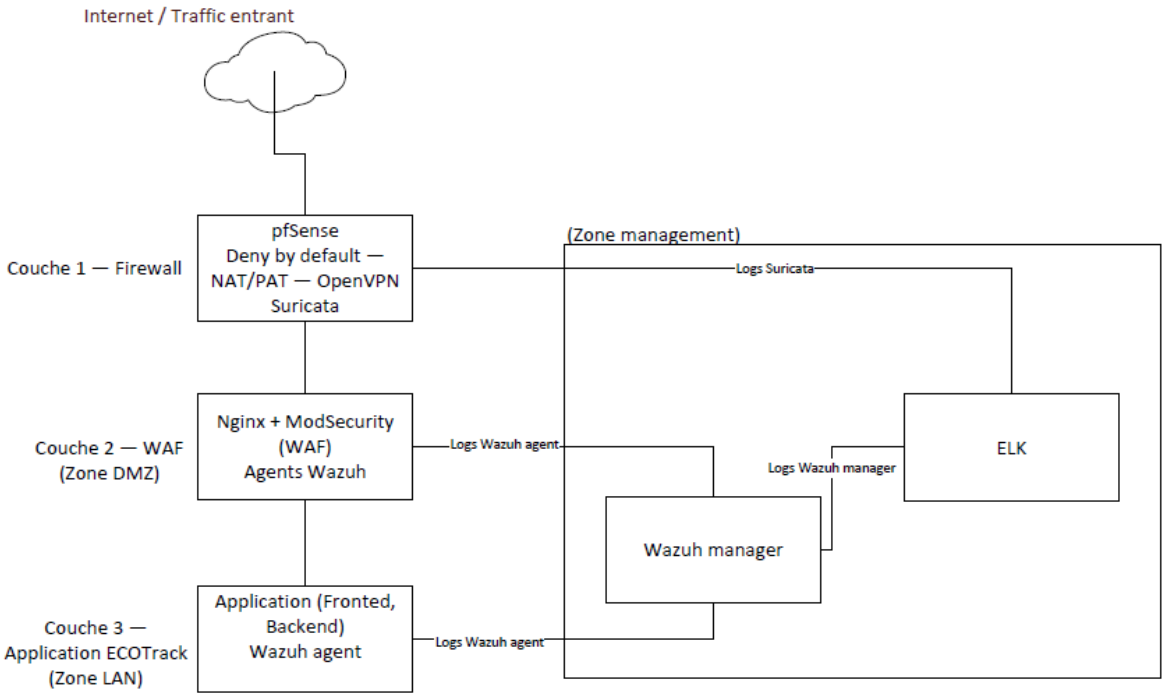
Composant	IP	Rôle
Wazuh Manager + Ansible	10.10.30.10	Corrélation et analyse des alertes sécurité + Déploiement et configuration IaC
Prometheus + Grafana + ELK Stack	10.10.30.20	Métriques et dashboards + Centralisation et visualisation des logs
Bastion SSH	10.10.30.40	Point d'accès SSH sécurisé
Windows server	10.10.30.30	Active Directory + DNS

VLAN 40 — Zone IoT — 10.10.40.0/24

La zone IoT isole l'ensemble des équipements connectés du reste de l'infrastructure. Elle héberge le broker MQTT Mosquitto qui centralise les données remontées par les 2 000 capteurs ultrasoniques déployés sur la métropole. Toutes les communications entre les capteurs et le broker sont chiffrés via TLS 1.3 avec authentification par certificats clients. Aucun flux direct n'est autorisé depuis cette zone vers la base de données — les données transitent exclusivement via l'API Backend en zone LAN, selon une règle firewall explicitement définie sur pfSense.

Composant	**IP**	**Rôle**
Mosquitto MQTT	10.10.40.10	Broker IoT — réception et authentification des messages capteurs
2 000 capteurs	10.10.40.x	Capteurs ultrasoniques — remontée niveau remplissage toutes les 15 min

B. Stack de Sécurité



Ce schéma illustre les couches de sécurité successives d'ECOTRACK selon le principe de défense en profondeur : filtrage pfSense (couche réseau), WAF ModSecurity (couche applicative), IDS/IPS Suricata (couche détection), agents Wazuh (couche endpoint), et ELK Stack (couche supervision). Il montre comment une attaque doit franchir chaque couche avant d'atteindre les données.

1. Firewall — pfSense

pfSense constitue le cœur de la politique de sécurité réseau d'ECOTRACK. Il applique une règle de base deny by default : tout trafic non explicitement autorisé est bloqué et journalisé. La translation d'adresses (NAT/PAT) est configurée pour masquer les IPs internes du LAN derrière l'adresse publique de la DMZ. L'ensemble des flux inter-VLANs est loggé en syslog vers l'ELK Stack pour garantir la traçabilité complète des connexions.

Politique par défaut : blocage implicite de tout trafic non autorisé

NAT/PAT : translation des adresses de la DMZ vers Internet

VPN : tunnel OpenVPN pour les accès administrateurs distants

Logs : tous les flux loggés vers ELK Stack (syslog)

2. IDS/IPS — Suricata

Suricata analyse le trafic réseau en temps réel sur l'ensemble des interfaces du firewall. Il opère en mode hybride : IDS pour la génération d'alertes sur les comportements suspects, et IPS pour le blocage automatique des attaques avérées. Les règles déployées combinent les signatures Emerging Threats Open et cinq règles personnalisées adaptées au contexte ECOTRACK (bruteforce SSH, bruteforce API, scan de ports, injection SQL, trafic IoT anormal). Ses logs EVE JSON sont acheminés via Logstash vers Elasticsearch pour indexation et visualisation dans Kibana.

Règles : Emerging Threats Open + 5 règles custom ECOTRACK

Mode IDS : génération d'alertes sur comportements suspects

Mode IPS : blocage automatique des attaques avérées

Performance : analyse line-rate jusqu'à 1 Gbps

Logs : EVE JSON → Logstash → Elasticsearch

3. WAF — Nginx + ModSecurity

ModSecurity est déployé en module embarqué dans Nginx, en zone DMZ, devant tous les services web exposés. Il filtre l'intégralité des requêtes HTTP/HTTPS entrantes avant qu'elles n'atteignent l'API Backend dans le LAN. Le Core Rule Set OWASP v4 est activé en mode blocage (paranoia level 2), offrant une protection contre les attaques du Top 10 OWASP : injections SQL, XSS, CSRF, RCE et inclusions de fichiers.

Règles : OWASP Core Rule Set v4 (paranoia level 2)

Protection : SQL injection, XSS, CSRF, RCE

Mode : blocage automatique des requêtes malveillantes

Logs : modsec_audit.log → Logstash → Elasticsearch

4. SIEM — Wazuh

Wazuh est déployé en architecture centralisée : un Wazuh Manager unique en zone Management, et des agents légers installés sur chaque serveur des zones DMZ et LAN. Les agents remontent les logs système, applicatifs et d'accès vers le Wazuh Manager qui assure uniquement la corrélation et la détection des scénarios d'attaque multi-étapes. Les alertes corrélées sont ensuite transmises via Logstash vers Elasticsearch pour stockage et visualisation dans Kibana, aux côtés des logs Suricata.

Wazuh Manager : déployé en zone Management (10.10.30.10)

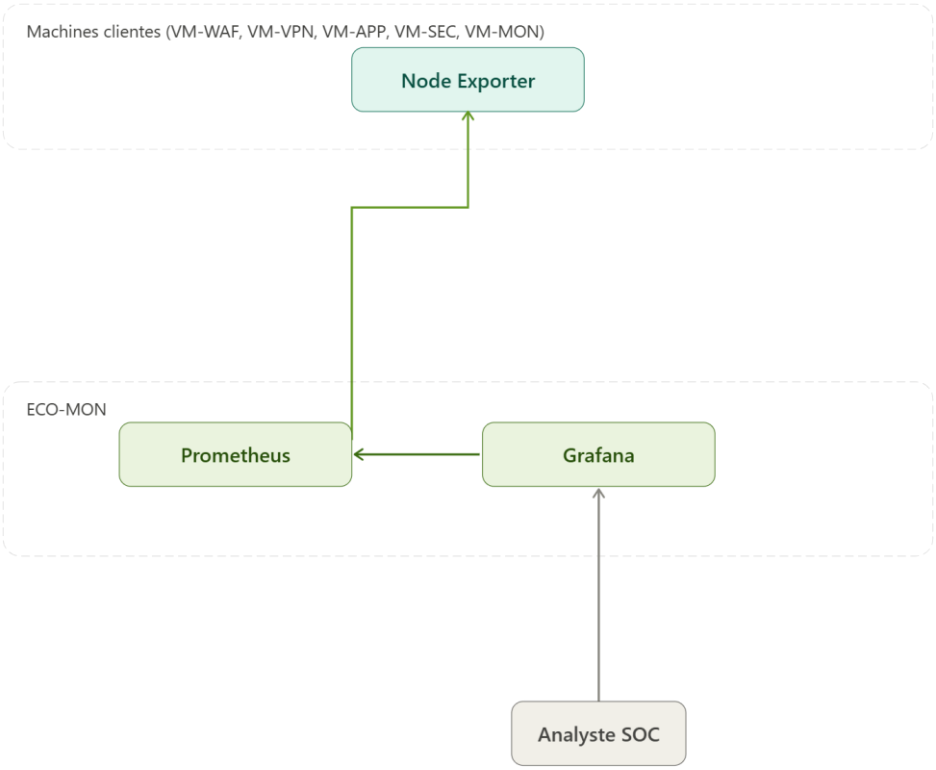
Agents : installés sur tous les serveurs DMZ et LAN

Rôle : corrélation des événements et détection d'intrusions

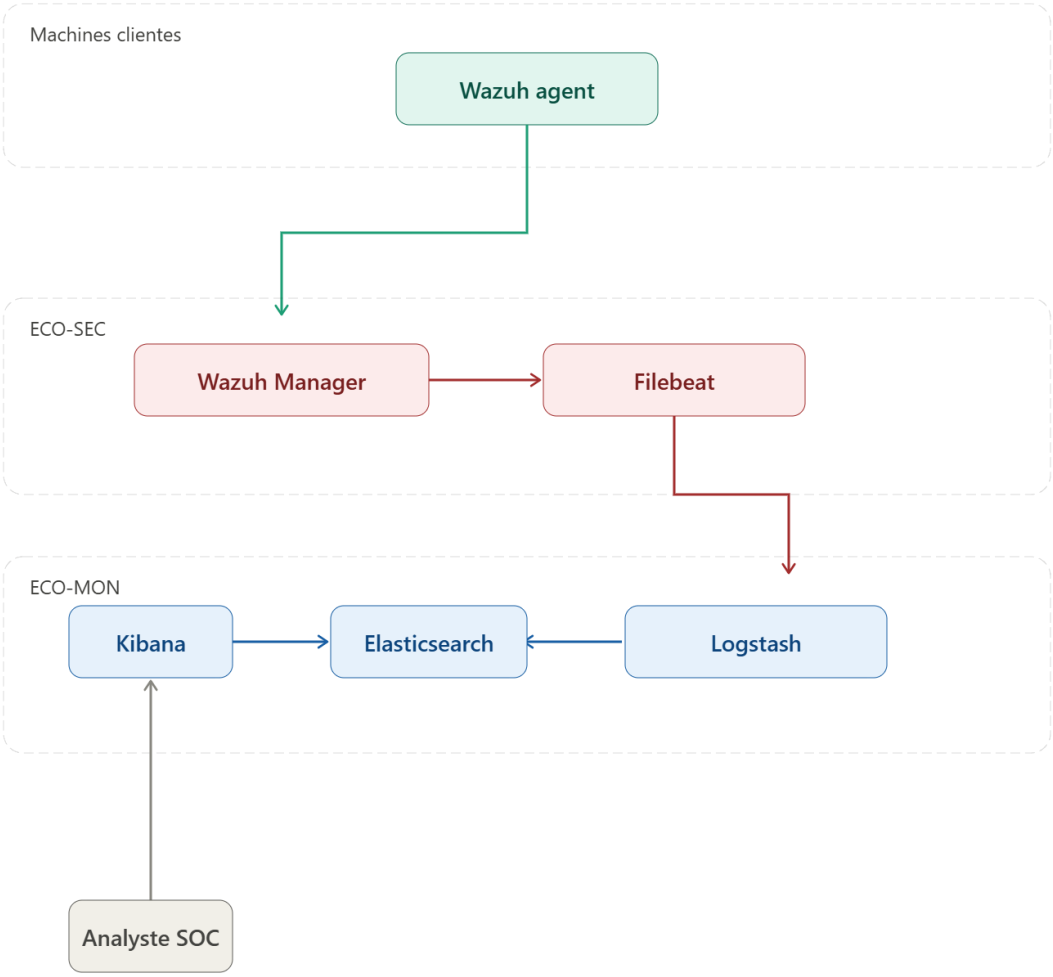
Flux : Wazuh Manager → Logstash → Elasticsearch → Kibana

Alertes : notifications email/SMS sur incidents critiques

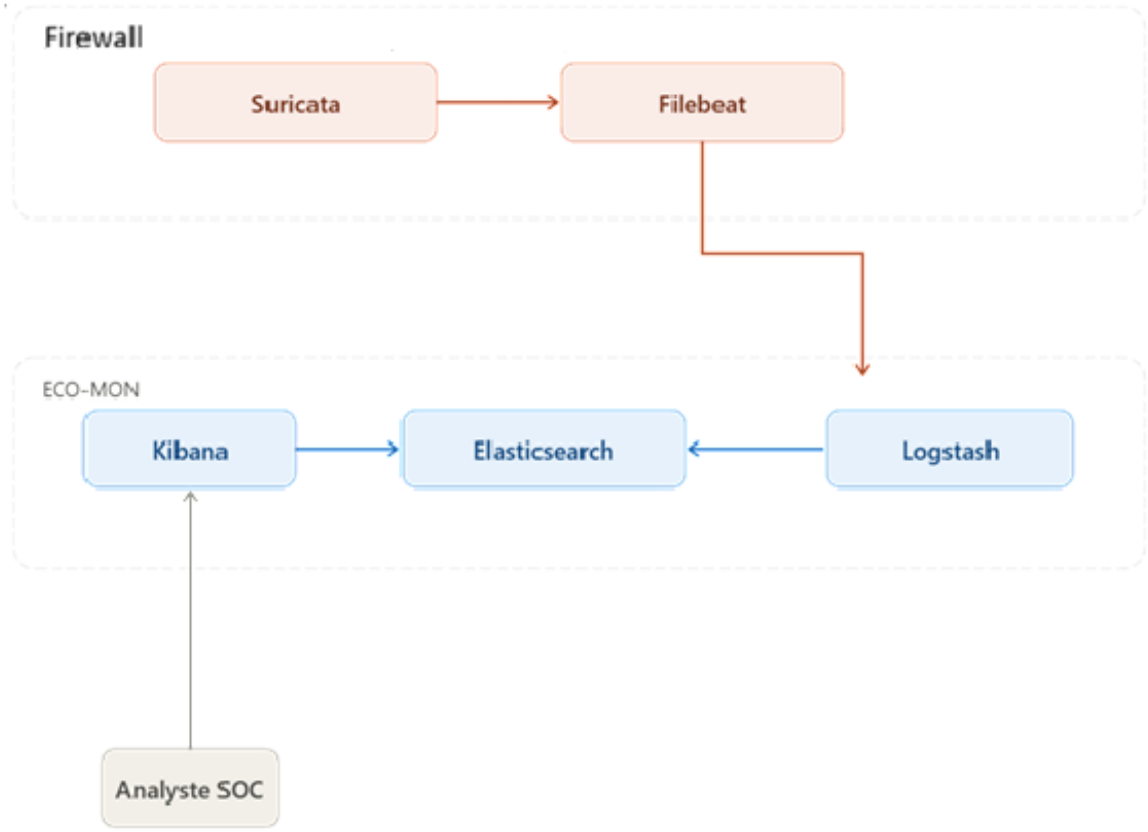
C. Monitoring et Supervision



Prometheus/Grafana


Machines clientes
Wazuh agent
ECO-SEC
Wazuh Manager
Filebeat
ECO-MON
Kibana
Elasticsearch
Logstash
Analyste SOC

Wazuh



Suricata

1. Stack de Monitoring

La supervision d'ECOTRACK repose sur deux flux de collecte complémentaires déployés en zone Management.

Collecte des logs (ELK Stack) :

Tous les événements de sécurité et logs applicatifs convergent vers un pipeline Logstash → Elasticsearch → Kibana centralisé. Deux sources alimentent ce pipeline : les alertes corrélées par le Wazuh Manager (logs système, accès, audit des serveurs DMZ et LAN) et les logs EVE JSON générés par Suricata (détection réseau). Kibana offre une interface de visualisation unifiée pour l'ensemble de ces événements, permettant des recherches forensiques et une rétention de 90 jours.

Collecte des métriques (Prometheus + Grafana) :

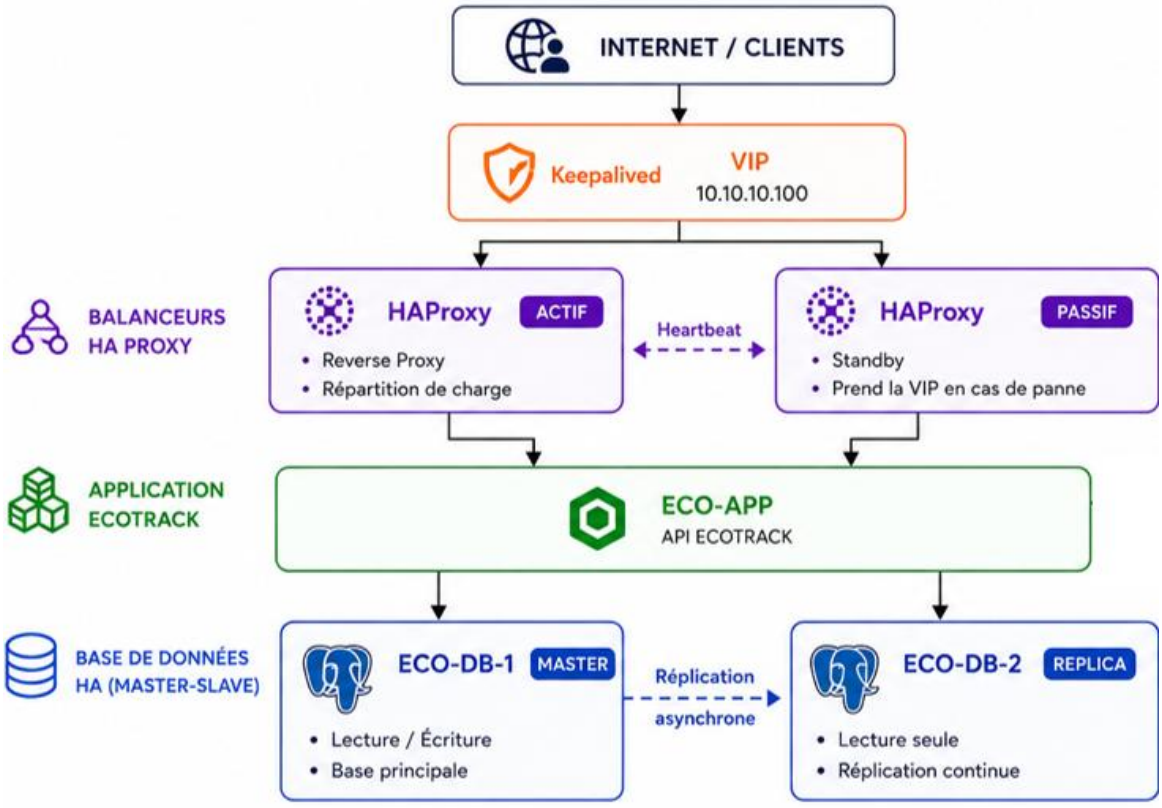
Chaque serveur de l'infrastructure expose ses métriques système via un agent Node Exporter local (CPU, RAM, disque, réseau). Prometheus scrape ces métriques toutes les 15 secondes depuis la zone Management et les conserve 15 jours en local. Grafana exploite cette source de données pour afficher 3 dashboards opérationnels en temps réel : infrastructure système, sécurité réseau, et activité IoT.

Alertes : Alertmanager gère les notifications sur dépassement de seuil et les achemine vers les canaux configurés (email, Slack).

2. KPIs Infrastructure

Indicateur	Cible	Outil de mesure
Disponibilité (Uptime)	≥ 99,5%	Grafana + Alertmanager
MTTD (détection incident)	< 5 minutes	Kibana + Wazuh
MTTR (résolution incident P1)	< 1 heure	Runbook + Alertmanager
Incidents sécurité critiques	0 par mois	Kibana
CPU serveurs	< 85%	Prometheus + Node Exporter
Espace disque	< 90%	Prometheus + Node Exporter

D. Haute Disponibilité



La haute disponibilité d'ECOTRACK est assurée à chaque couche de l'infrastructure pour respecter l'objectif de 99,5% d'uptime défini dans le cahier des charges.

Load Balancing : HAProxy est déployé en configuration actif/passif avec Keepalived gérant une VIP (Virtual IP) flottante. En cas de défaillance du nœud actif, le nœud passif prend la main en moins de 30 secondes sans interruption visible pour les utilisateurs.

Base de données : PostgreSQL est configuré en réplication streaming master-slave. Le slave est maintenu en temps réel et peut être promu master manuellement en cas de défaillance, garantissant un RPO inférieur à 1 heure.

Sauvegardes : la stratégie 3-2-1 est appliquée — 3 copies des données, sur 2 supports différents, dont 1 copie hors site. Les sauvegardes sont chiffrées (AES-256) et testées mensuellement.

Tests de reprise : un exercice de disaster recovery est réalisé chaque trimestre pour valider les procédures de reprise et s'assurer du respect du RTO de 4 heures.

4.3 Scalabilité et performance

A. Stratégies de Scalabilité

1. Scalabilité Horizontale

La scalabilité horizontale d'ECOTRACK repose sur l'ajout d'instances supplémentaires derrière HAProxy sans interruption de service. Cette approche est privilégiée car elle permet de répondre aux pics de charge (collectes simultanées, alertes massives) sans modifier l'architecture existante.

- Load balancing : HAProxy distribue le trafic entrant sur N instances de l'API Backend en round-robin. L'ajout d'une nouvelle instance se fait sans interruption de service grâce à la VIP Keepalived.
- Base de données : des read replicas PostgreSQL absorbent les requêtes en lecture (dashboards, analytics) pour décharger le master qui ne traite que les écritures.
- Cache : Redis est configurable en mode cluster avec sharding pour distribuer la charge de cache sur plusieurs nœuds en cas de montée en charge.

2. Scalabilité Verticale

La scalabilité verticale consiste à augmenter les ressources (CPU, RAM, IOPS) d'un serveur existant. Elle est utilisée en premier recours pour les composants dont la parallélisation est complexe.

- Cas d'usage principaux : le serveur PostgreSQL master et le serveur ELK Stack sont les premiers candidats à la scalabilité verticale, leur nature centralisée rendant la distribution plus complexe.

- Limites : la scalabilité verticale atteint rapidement le plafond matériel et son coût croît de façon non linéaire. Elle constitue une solution temporaire avant de basculer vers une approche horizontale.

B. Objectifs de Performance

Les objectifs de performance sont définis dans le cahier des charges et constituent des indicateurs contractuels mesurés en continu via Prometheus et Grafana.

Métrique	Cible	Outil de mesure
Temps réponse API	< 500ms P95	Prometheus + Grafana
Latence ingestion IoT	< 2s end-to-end	Prometheus + Node Exporter
Débit messages IoT	400 msg/min	Prometheus + Mosquitto exporter
Utilisateurs simultanés	500	Tests de charge k6
Disponibilité	99,5% (43h downtime/an max)	Grafana + Alertmanager
Cache hit ratio	> 80%	Redis exporter + Grafana

C. Tests de Charge Prévus

Les tests de charge sont intégrés au cycle de développement Agile et réalisés à trois étapes clés du projet pour valider la tenue en charge avant la mise en production.

- Outils : k6 pour les tests de charge HTTP (scénarios scriptés en JavaScript), Apache JMeter pour les tests de stress sur l'API REST, et Locust pour simuler le comportement des utilisateurs concurrents.
- Scénarios testés : montée en charge progressive (100, 500, 1 000 utilisateurs simultanés), pic soudain (simulation d'une alerte massive sur tous les conteneurs), et endurance (charge soutenue pendant 1 heure).
- Fréquence : un test de charge est réalisé à la fin du Sprint 2 (fondations), du Sprint 4 (fonctionnalités avancées) et du Sprint 5 (avant mise en production).
- Métriques collectées : throughput (requêtes/seconde), latence (P50, P95, P99), taux d'erreur (HTTP 5xx), et consommation ressources (CPU, RAM) via Prometheus pendant les tests.

4.4 Sécurité et conformité

A. Authentification et Autorisation

La stratégie d'authentification d'ECOTRACK repose sur un système de tokens JWT combiné à une gestion fine des rôles (RBAC), garantissant que chaque utilisateur n'accède qu'aux ressources strictement nécessaires à son activité.

- JWT : chaque authentification réussie génère deux tokens — un access token (durée de vie 15 minutes) et un refresh token (durée de vie 7 jours). Cette durée courte de l'access token limite l'impact d'un vol de token en réduisant la fenêtre d'exploitation.
- 2FA : l'authentification à double facteur via TOTP (Google Authenticator ou équivalent) est obligatoire pour les comptes Administrateurs et Gestionnaires. Elle constitue une exigence non négociable pour l'accès à la zone Management via VPN.
- RBAC : quatre rôles sont définis selon le principe du moindre privilège — Administrateur (accès total), Gestionnaire (supervision et configuration), Agent de collecte (tournées et signalements), Citoyen (signalements et gamification). Chaque rôle est vérifié à chaque requête API.
- Sessions : les sessions utilisateurs sont stockées dans Redis avec un TTL aligné sur la durée de vie du refresh token. La révocation d'une session est immédiate et effective sur l'ensemble de l'infrastructure.
- Mots de passe : hachage bcrypt avec un cost factor de 12, longueur minimale de 12 caractères imposée. Cinq tentatives d'authentification échouées consécutives déclenchent un blocage temporaire du compte et une alerte Wazuh.

B. Chiffrement

Le chiffrement est appliqué à tous les niveaux de l'infrastructure, aussi bien sur les données en transit qu'au repos, conformément aux recommandations de l'ANSSI.

- Transport : TLS 1.3 est obligatoire sur l'ensemble des flux exposés. Les suites de chiffrement obsolètes (TLS 1.0, 1.1, SSLv3) sont explicitement désactivées sur Nginx. Les communications MQTT entre les capteurs IoT et le broker Mosquitto sont également chiffrées via TLS avec authentification par certificats clients.
- At-rest : les données sensibles stockées dans PostgreSQL (données personnelles citoyens, logs d'accès) sont chiffrées en AES-256. Les sauvegardes sont chiffrées avec la même norme avant transfert hors site.

- Gestion des secrets : les credentials, clés API et certificats sont centralisés dans HashiCorp Vault déployé en zone Management. Aucun secret n'est stocké en clair dans les fichiers de configuration ou les dépôts Git.
- Certificats : les certificats TLS sont générés et renouvelés automatiquement via Let's Encrypt et Certbot. Une alerte Alertmanager est configurée 30 jours avant l'expiration de tout certificat.

C. Conformité RGPD

ECOTRACK traite des données personnelles de 15 000 citoyens actifs et de 50 agents de collecte. La conformité RGPD est intégrée dès la conception de l'architecture, selon le principe de Privacy by Design.

- Consentement : un opt-in explicite est recueilli lors de l'inscription pour chaque finalité de traitement (géolocalisation, gamification, notifications). Le refus d'un consentement n'empêche pas l'accès aux fonctionnalités de base.
- Droit d'accès : un endpoint dédié GET /me/data permet à chaque utilisateur d'accéder à l'ensemble de ses données personnelles stockées dans la plateforme, au format JSON.
- Droit à l'effacement : la suppression d'un compte déclenche un soft delete immédiat (données masquées) suivi d'une purge définitive sous 90 jours. Les logs d'audit sont anonymisés mais conservés pour des raisons de sécurité.
- Portabilité : les données personnelles sont exportables à la demande aux formats JSON et CSV via l'interface utilisateur.
- Minimisation : seules les données strictement nécessaires à chaque finalité sont collectées. Les données de géolocalisation des agents sont supprimées automatiquement 30 jours après la fin de la tournée.
- DPO : un Délégué à la Protection des Données est désigné. Un registre des traitements est maintenu et mis à jour à chaque évolution de l'architecture.

D. Recommandations ANSSI

L'architecture d'ECOTRACK est alignée sur les guides de l'ANSSI applicables aux infrastructures hébergeant des données sensibles.

- Cloisonnement réseau : la segmentation en VLANs avec filtrage pfSense respecte les recommandations du guide ANSSI sur la sécurisation des architectures réseau. Chaque zone constitue un domaine de confiance indépendant.

- DevSecOps : la sécurité est intégrée au pipeline CI/CD. Trivy analyse les images Docker à chaque build pour détecter les vulnérabilités connues. Les configurations Ansible sont auditées par Checkov avant déploiement.
- Journalisation : conformément aux recommandations ANSSI, l'ensemble des logs système, réseau et applicatifs est conservé pendant 12 mois dans l'ELK Stack. Un audit trail complet de toutes les actions administrateurs est maintenu et horodaté.
- Hardening serveurs : les serveurs Debian 12 sont durcis selon le guide ANSSI — désactivation du login root SSH, authentification par clé uniquement, pare-feu local UFW activé, mises à jour de sécurité automatiques via unattended-upgrades.

5.Modelisation

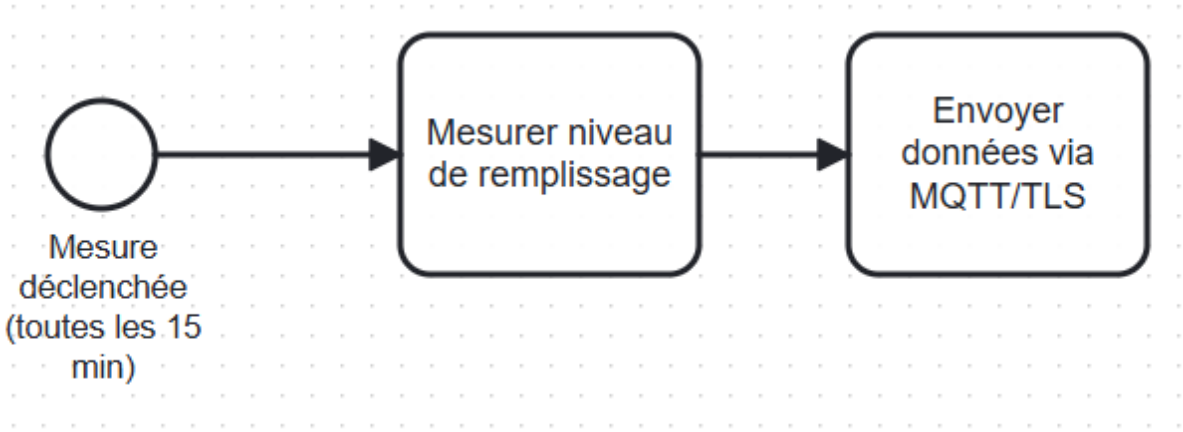
5.1 Modélisation BPMN

A. Introduction BPMN 2.0

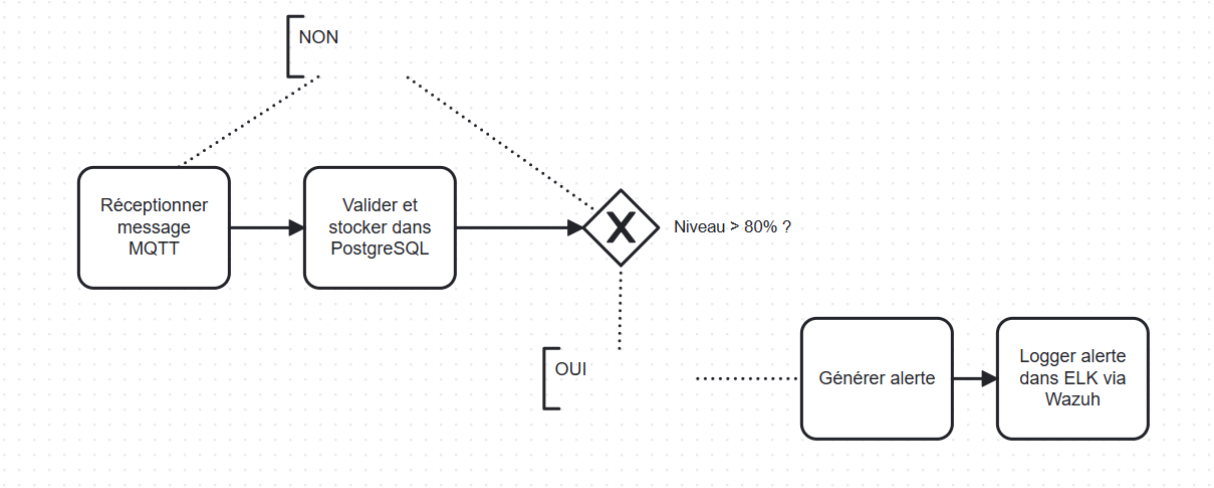
La modélisation BPMN 2.0 (Business Process Model and Notation) est un standard graphique permettant de représenter des processus métier de façon claire et universelle. Elle repose sur quatre éléments fondamentaux : les événements (cercles) qui marquent le début et la fin d'un processus, les tâches (rectangles arrondis) qui représentent les actions à effectuer, les passerelles (losanges) qui modélisent les décisions et les branchements conditionnels, et les pools/lanes (grandes zones rectangulaires subdivisées) qui délimitent les acteurs ou systèmes impliqués dans le processus. Les éléments sont reliés par des flux de séquence (flèches pleines) indiquant l'ordre d'exécution. Les diagrammes BPMN du projet ECOTRACK ont été réalisés avec BPMN.io .

B. Processus 1 : Remontée d'Alerte

- Lane 1 : **Capteur IoT**



- Lane 2 : **Système ECOTRACK** (API + Suricata + Wazuh)



- Lane 3 : **Gestionnaire**

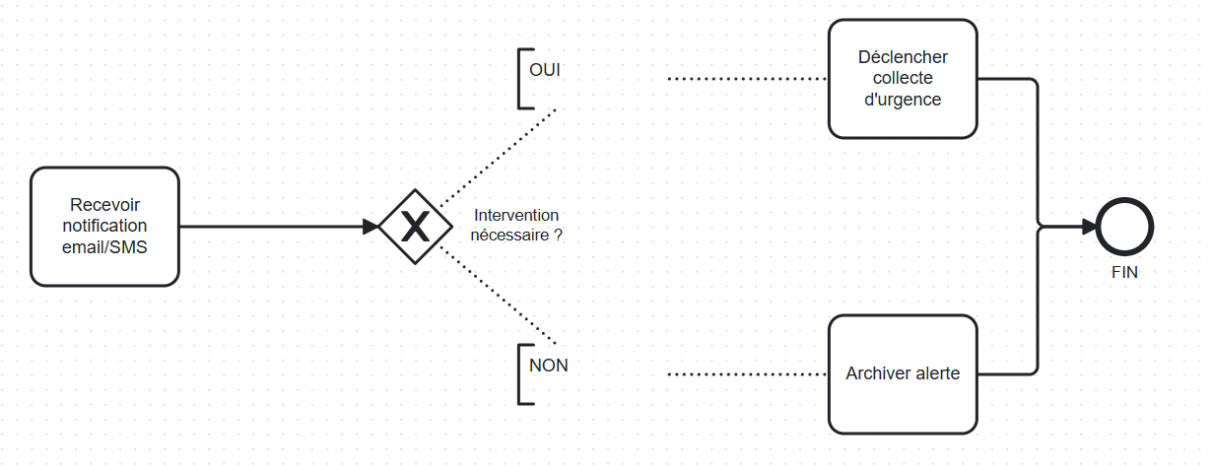
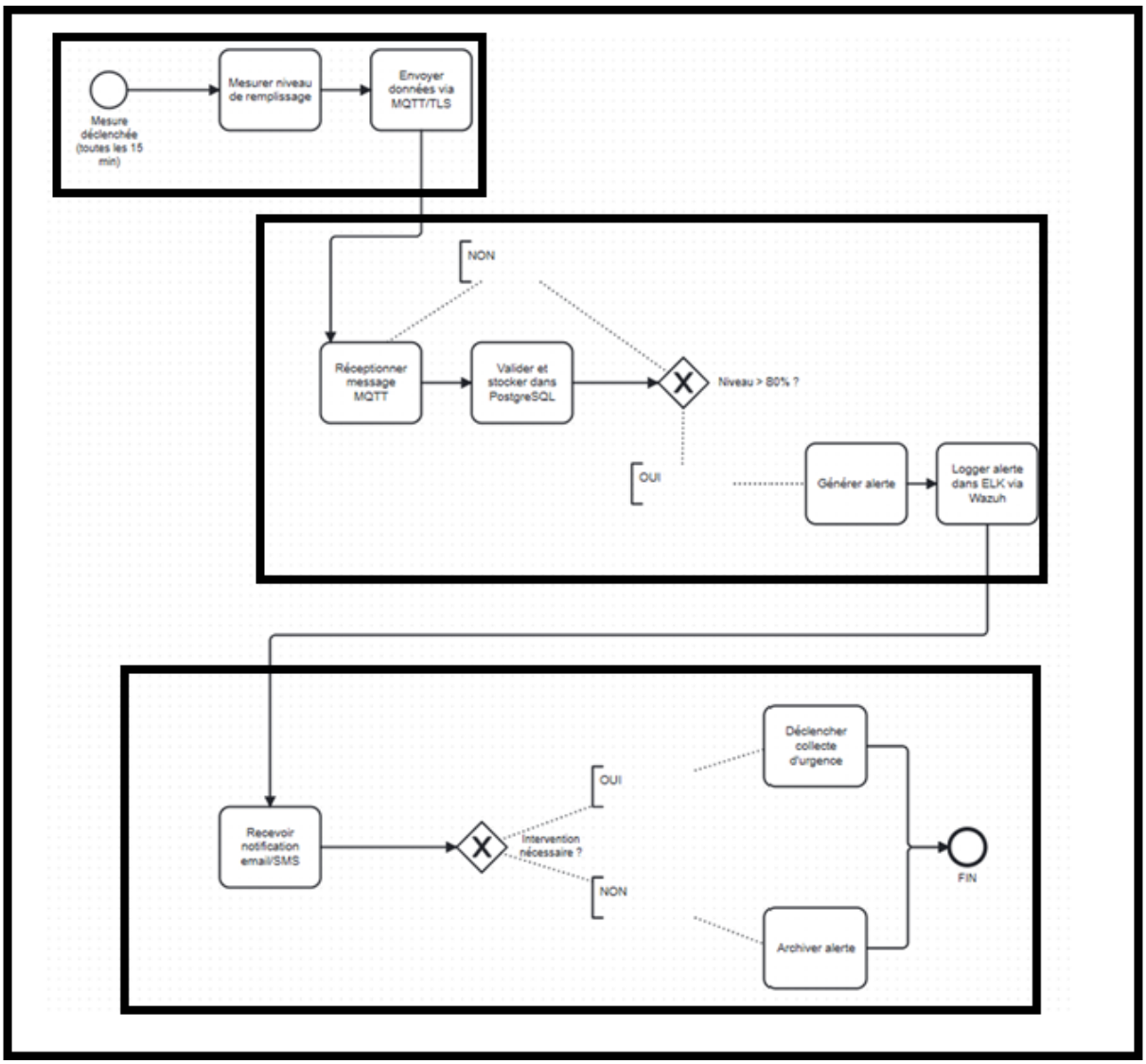


Diagramme général :



Description du processus :

Le processus de remontée d'alerte débute par la mesure automatique du niveau de remplissage d'un conteneur par son capteur ultrasonique, déclenchée toutes les 15 minutes. La donnée est transmise via MQTT chiffré en TLS vers le broker Mosquitto, puis validée et stockée dans PostgreSQL par l'API Backend. Une passerelle vérifie si le seuil critique de 80% est atteint — si ce n'est pas le cas, le processus se termine et reprendra à la prochaine mesure. Si le seuil est dépassé, une alerte est générée, loggée dans l'ELK Stack via Wazuh, et une notification est immédiatement envoyée au gestionnaire de zone par email et SMS. Ce dernier décide alors soit de déclencher une collecte d'urgence, soit d'archiver l'alerte si une intervention est déjà planifiée.

C. Processus 2 : Détection et Réponse à Incident de Sécurité

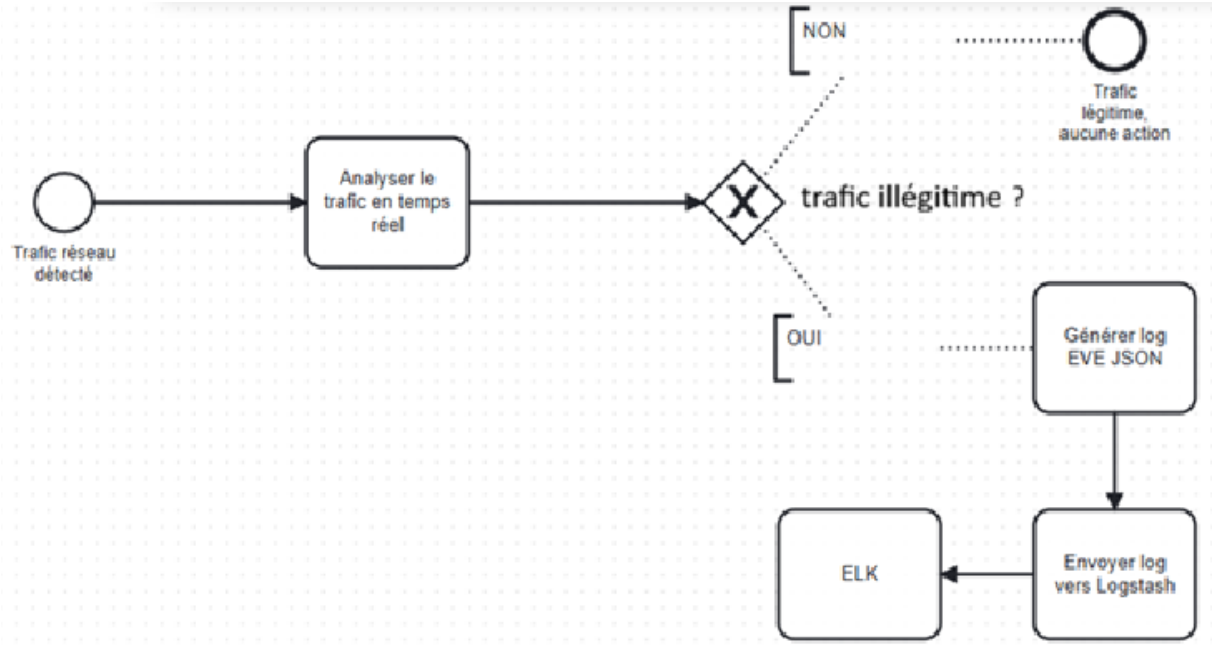
Pourquoi ce processus plutôt que l'optimisation de tournée :

L'optimisation de tournée est un processus métier qui appartient à la filière Développement. En Cyber & Réseaux, le processus le plus représentatif et le plus pertinent est la détection et réponse à incident de sécurité — c'est le cœur du métier SOC qu'on a mis en place avec Suricata et Wazuh.

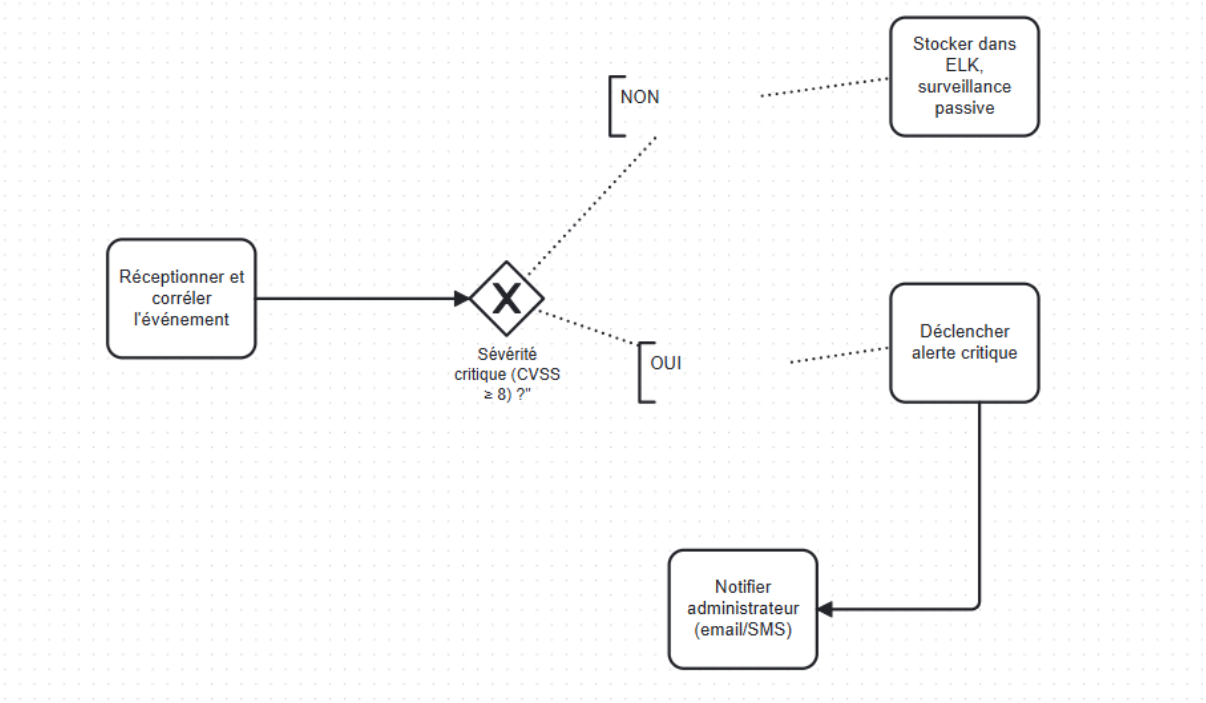
Description du diagramme à réaliser :

Le diagramme comporte 3 lanes dans un même pool :

- Lane 1 : **Suricata IDS**



- Lane 2 : **Wazuh SIEM**



- Lane 3 : **Administrateur**

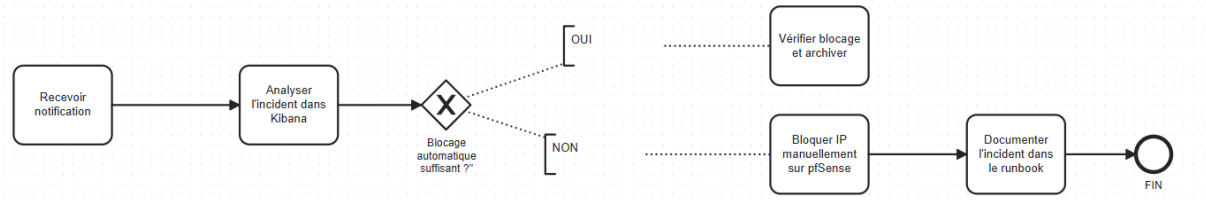
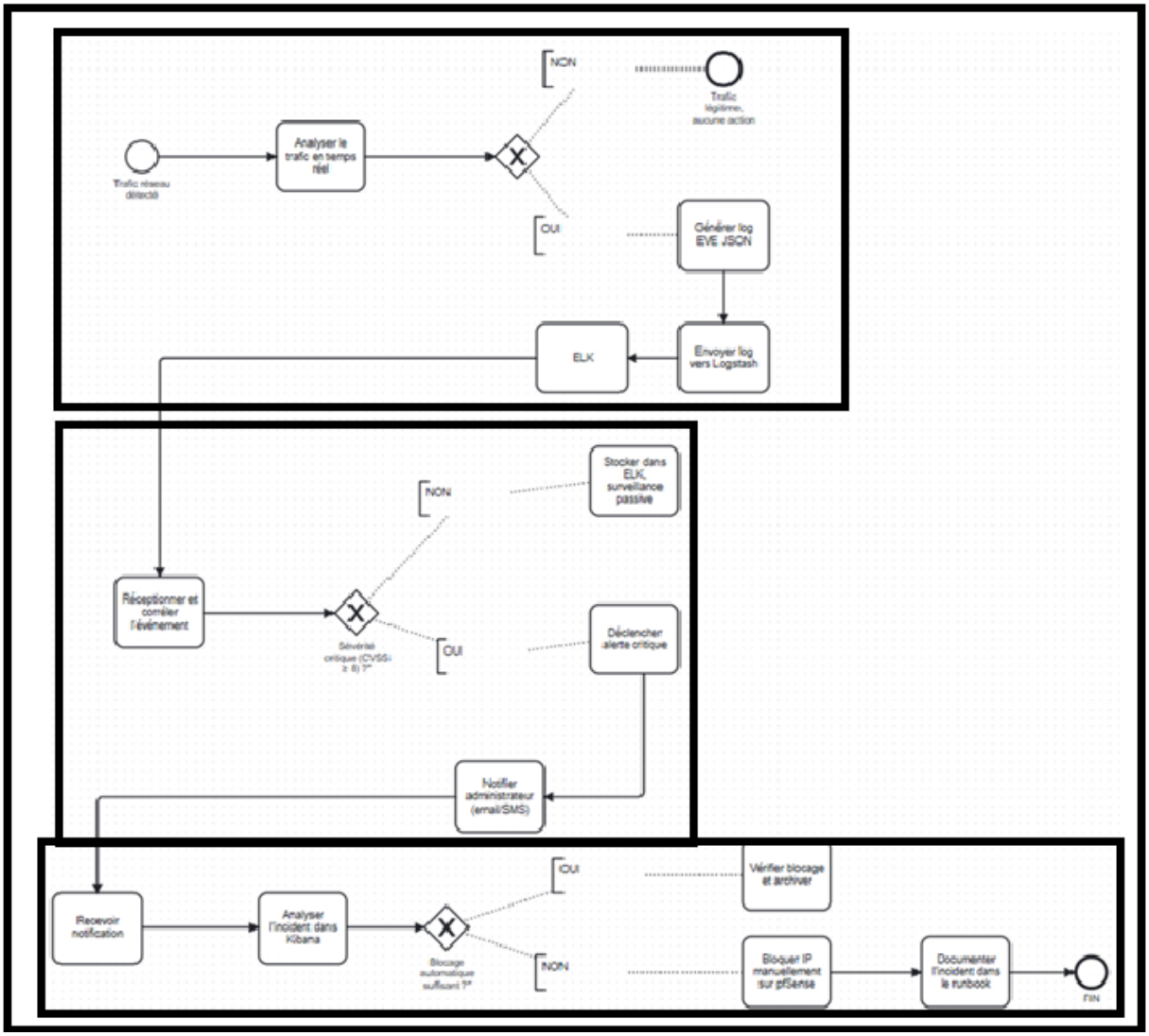


Diagramme général :



Description du processus :

Le processus de détection et réponse à incident débute dès qu'un flux réseau est capturé par Suricata en zone Management. Suricata analyse ce trafic en temps réel et le compare à ses règles de détection — si aucune correspondance n'est trouvée, le flux est considéré comme légitime. Dans le cas contraire, un log EVE JSON est généré et transmis via Logstash vers Elasticsearch. Wazuh récupère cet événement et applique ses règles de corrélation pour évaluer la sévérité de la menace. Si la sévérité est critique (CVSS ≥ 8), une alerte est déclenchée et l'administrateur est notifié immédiatement. Ce dernier analyse l'incident dans Kibana et décide soit de valider le blocage automatique déjà appliqué, soit d'intervenir manuellement sur pfSense pour bloquer l'IP source. L'incident est systématiquement documenté dans le runbook de sécurité pour alimenter le retour d'expérience.

5.2 Conclusion

Le choix de la méthode BPMN 2.0 pour la modélisation du projet ECOTRACK s'est imposé naturellement au regard de la filière Cyber & Réseaux. Contrairement à UML qui modélise des structures orientées objet, ou à MERISE qui se concentre sur les données relationnelles, BPMN permet de représenter graphiquement des processus opérationnels séquentiels impliquant plusieurs acteurs et systèmes. Or, le cœur du métier SOC repose précisément sur des processus de ce type : une alerte de sécurité suit un enchaînement d'étapes précis, implique des systèmes automatisés (Suricata, Wazuh) et des décisions humaines (administrateur), et doit être documentée de façon non ambiguë pour être reproductible.

Les deux processus modélisés illustrent les flux les plus critiques de l'infrastructure ECOTRACK. Le processus de remontée d'alerte IoT couvre le cycle complet depuis la mesure d'un capteur jusqu'à la décision du gestionnaire, en passant par la validation des données et le déclenchement conditionnel de l'alerte. Le processus de détection et réponse à incident de sécurité modélise quant à lui la chaîne SOC complète — de la détection Suricata à la remédiation manuelle sur pfSense — en rendant visible chaque point de décision et chaque responsabilité. Cette représentation est directement exploitable comme base pour les runbooks d'incident documentés dans la PSSI.

Enfin, BPMN 2.0 présente un avantage pratique majeur dans un contexte de projet multi-filières : sa lisibilité universelle permet aux équipes Développement et Data Science de comprendre les processus de sécurité sans connaissance préalable en cybersécurité. Les diagrammes produits constituent ainsi un outil de communication transversal entre les trois filières du projet, facilitant les points de synchronisation hebdomadaires et la cohérence globale de l'architecture ECOTRACK.

6.Planification agile

6.1 Choix de la méthodologie agile

Pour le projet ECOTRACK, l'adoption de la méthodologie Agile Scrum est indispensable pour synchroniser les impératifs de sécurité et d'infrastructure avec le cycle de développement applicatif. Cette approche par itérations courtes de deux semaines permet de déployer l'architecture réseau de manière modulaire, garantissant que chaque brique technologique, comme l'ingestion de données IoT, est immédiatement protégée par des règles de firewalling et un monitoring adapté. La flexibilité de Scrum est particulièrement pertinente pour la spécialité Cyber-Réseaux, car elle permet d'ajuster les politiques de sécurité en fonction des vulnérabilités détectées lors des tests d'intégration continus. Enfin, les démonstrations régulières assurent une validation constante des accès sécurisés par les utilisateurs finaux, évitant ainsi tout blocage réseau critique en fin de projet.

A. Framework Scrum

- **Rôles :**
    - **Product Owner :** Responsable de la vision métier et de la priorisation du backlog.
    - **Scrum Master :** Garant de la méthodologie, il lève les obstacles techniques et facilite la communication entre les spécialités.
    - **Équipe Dev :** Équipe pluridisciplinaire chargée de l'implémentation technique des sprints.
- **Événements :**
    - **Sprint Planning :** Sélection des tâches réseau et sécurité à réaliser pour le sprint.
    - **Daily Stand-up :** Point quotidien de 15 minutes pour coordonner l'avancement.
    - **Sprint Review :** Démonstration des fonctionnalités et de l'infrastructure opérationnelle.
    - **Rétrospective :** Analyse des points d'amélioration de l'équipe à la fin de chaque itération.
- **Artefacts :**
    - **Product Backlog :** Liste ordonnée de toutes les exigences du projet.
    - **Sprint Backlog :** Liste des tâches spécifiques retenues pour le sprint en cours.

- **Incrément :** Version potentiellement livrable et sécurisée du produit à la fin du sprint.

B. Organisation en Sprints

- **Durée d'un sprint :** 2 semaines.
- **Nombre de sprints :** 8 sprints.
- **Durée totale projet :** 16 semaines.

6.2 Backlog produit

ID	Rôle	Action (User Story)	Bénéfice	Priorité (MoSCoW)	Points (SP)
US-001	Admin Réseau	Configurer 4 VLANs (DMZ, LAN, MGT, IoT)	Isoler les flux et segmenter l'infrastructure	**MUST**	8
US-002	Expert Cyber	Déployer le firewall pfSense avec 15 règles	Contrôler strictement les accès inter-zones	**MUST**	13
US-003	Expert Cyber	Configurer un Reverse Proxy (HAProxy)	Protéger les serveurs web des attaques directes	**MUST**	8
US-004	Admin Système	Déployer 7 VMs sécurisées sur l'hyperviseur	Fournir les ressources aux équipes Dev et Data	**MUST**	5
US-005	Analyste SOC	Installer l'IDS Suricata avec 5 règles personnalisées	Détecter les tentatives d'intrusion en temps réel	**MUST**	13
US-006	Ingénieur Cyber	Sécuriser le broker MQTT via TLS 1.3	Garantir l'intégrité des données des capteurs	**MUST**	8

ID	Rôle	Action (User Story)	Bénéfice	Priorité (MoSCoW)	Points (SP)
US-007	Admin Réseau	Mettre en place un VPN (OpenVPN/WireGuard)	Sécuriser les accès d'administration à distance	**MUST**	5
US-008	Analyste SOC	Centraliser les logs (ELK/Wazuh)	Avoir une visibilité complète sur les événements	**MUST**	8
US-009	Expert Cyber	Implémenter un WAF (Web Application Firewall)	Bloquer les injections SQL et attaques XSS	**SHOULD**	8
US-010	Admin Système	Automatiser les sauvegardes des VMs	Assurer la résilience en cas de panne majeure	**SHOULD**	5
US-011	Expert Cyber	Configurer l'authentification Double Facteur (2FA)	Renforcer la sécurité des accès administrateurs	**SHOULD**	3
US-012	Analyste SOC	Configurer des alertes critiques sur Discord/Slack	Réagir en moins de 5 minutes aux incidents	**SHOULD**	5
US-013	Admin Réseau	Mettre en place une VIP (Virtual IP) pour le failover	Garantir la haute disponibilité du réseau	**SHOULD**	8
US-014	Auditeur	Réaliser un scan de vulnérabilités (Nessus/OpenVAS)	Identifier et corriger les failles avant la MEP	**SHOULD**	5
US-015	Admin Système	Appliquer le durcissement (Hardening) OS	Réduire la surface d'attaque des serveurs	**COULD**	3

ID	Rôle	Action (User Story)	Bénéfice	Priorité (MoSCoW)	Points (SP)
US-016	Expert Cyber	Mettre en place un pot de miel (Honeypot)	Identifier les méthodes des attaquants	**COULD**	5
US-017	Analyste SOC	Créer un tableau de bord sécurité sur Grafana	Visualiser l'état de santé de l'infrastructure	**COULD**	5
US-018	Expert Cyber	Implémenter la rotation automatique des mots de passe	Limiter l'impact en cas de compromission	**COULD**	3
US-019	Auditeur	Rédiger les procédures de réponse aux incidents	Préparer l'équipe à réagir efficacement	**COULD**	3
US-020	Admin Réseau	Tester la restauration du Plan de Reprise d'Activité	Valider la capacité de survie du système	**COULD**	8

6.3 Planification par sprint

Sprint 1 (Semaines 1-2) : Socle Technique & Infrastructure

- User Stories : [US-001, US-004, US-007] — Total : 18 SP
- Objectif : Mise en place de l'environnement de virtualisation, de la segmentation réseau primaire et de l'annuaire d'entreprise.
- Livrables : Hyperviseur opérationnel, 7 VMs provisionnées, 4 VLANs configurés, Active Directory et DNS configurés.

Sprint 2 (Semaines 3-4) : Sécurisation Périmétrique

- User Stories : [US-002, US-003] — Total : 21 SP
- Objectif : Déploiement du point d'entrée unique pour le trafic Web et gestion des identités.
- Livrables : DMZ sécurisée avec Nginx et HAProxy opérationnels, gestion des identités et RBAC configurés.

Sprint 3 (Semaines 5-6) : Accès Distant & Chiffrement

- User Stories : [US-006, US-013] — Total : 16 SP
- Objectif : Sécurisation des accès distants et chiffrement global des flux.
- Livrables : OpenVPN configuré avec 2FA, haute disponibilité pfSense opérationnelle, HTTPS/TLS actif sur tous les services exposés.

Sprint 4 (Semaines 7-8) : Détection & Protection Applicative

- User Stories : [US-005, US-009] — Total : 21 SP
- Objectif : Mise en place de la détection d'intrusion et de la protection des interfaces web.
- Livrables : WAF ModSecurity actif avec OWASP CRS v4, IDS/IPS Suricata opérationnel avec 5 règles custom ECOTRACK.

Sprint 5 (Semaines 9-10) : Monitoring & Centralisation des Logs

- User Stories : [US-008, US-012, US-017] — Total : 18 SP
- Objectif : Mise en place de la supervision de l'infrastructure et centralisation des événements de sécurité.
- Livrables : Stack Prometheus/Grafana opérationnelle avec dashboards de santé infrastructure, Wazuh Manager déployé avec agents sur toutes les VMs, Stack ELK fonctionnelle avec alertes critiques configurées.

Sprint 6 (Semaines 11-12) : Haute Disponibilité & Supervision Avancée

- User Stories : [US-011, US-013] — Total : 11 SP
- Objectif : Renforcement de la résilience de l'infrastructure et supervision avancée.
- Livrables : PostgreSQL HA avec Patroni/etcd opérationnel, supervision avancée et dashboards de sécurité complétés.

Sprint 7 (Semaines 13-14) : Tests d'Intrusion & Durcissement

- User Stories : [US-014, US-015, US-016] — Total : 13 SP
- Objectif : Validation de la robustesse du système et réduction de la surface d'attaque.
- Livrables : Pipeline CI/CD GitLab opérationnel, rapport de scan de vulnérabilités Nessus/OpenVAS, serveurs durcis (OS Hardening).

Sprint 8 (Semaines 15-16) : Résilience & Documentation Finale

- User Stories : [US-010, US-018, US-019, US-020] — Total : 19 SP
- Objectif : Finalisation de la conformité, préparation au passage en production et documentation technique globale.

- Livrables : Politique de Sécurité du SI (PSSI), procédures de réponse aux incidents (Runbooks), Plan de Reprise d'Activité (PRA) testé, documentation technique globale complète.

6.4 Outils de gestion

Pour garantir la réussite du projet ECOTRACK et la fluidité entre les équipes, nous utiliserons la stack d'outils suivante :

- **Outil principal : GitHub Projects** Nous centralisons la gestion du Backlog et le suivi des Sprints directement sur GitHub Projects via un tableau Kanban. Cela permet de lier directement les tâches d'infrastructure (ex: configuration pfSense) aux commits et aux pull requests.
- **Communication : Discord** Discord sera notre hub de communication principal. Nous y avons configuré des canaux dédiés par spécialité (Cyber, Dev, Data) ainsi que des webhooks pour recevoir des notifications en temps réel lors des déploiements ou des alertes de sécurité.
- **Versioning : GitHub avec GitFlow** L'ensemble des scripts de configuration (Infrastructure as Code), les règles Suricata et les fichiers YAML de déploiement sont versionnés sur GitHub. Nous utilisons la méthodologie **GitFlow** (branches main pour la production, develop pour l'intégration, et des branches feature pour chaque US) afin de garantir la stabilité de l'infrastructure.
- **CI/CD : GitHub Actions** L'automatisation est assurée par GitHub Actions pour valider la syntaxe des scripts de configuration, lancer des scans de sécurité sur le code (SAST) et automatiser le déploiement des conteneurs après validation des tests.
- **Documentation : Notion** Notion sert de base de connaissances centrale. Il héberge la **PSSI**, les schémas d'architecture réseau (VLANs), le dictionnaire des données et les procédures de réponse aux incidents (Runbooks) accessibles par toute l'équipe.

6.5 Indicateurs clés de performance (KPI)

Pour mesurer l'efficacité de l'infrastructure et le niveau de sécurité du projet ECOTRACK, nous suivrons les indicateurs suivants :

KPIs Infrastructure & Sécurité (Spécifiques Cyber)

1. **Disponibilité infrastructure :** Mesure de l'Uptime des services critiques (Proxy, MQTT, DB). | Cible ≥ 99.9% | Mesure : Temps réel.
2. **Incidents de sécurité majeurs :** Nombre d'intrusions ou de compromissions réussies détectées. | Cible : 0 critique | Mesure : Journalier.

3. **Temps moyen de détection (MTTD) :** Délai entre le début d'une anomalie et l'alerte de l'IDS. | Cible < 5 min | Mesure : Par incident.
4. **Temps moyen de résolution (MTTR) :** Délai entre la détection et le rétablissement du service sécurisé. | Cible < 1h | Mesure : Par incident.
5. **Vulnérabilités critiques :** Nombre de CVE critiques non patchées sur les 7 serveurs. | Cible : 0 | Mesure : Hebdomadaire.
6. **Conformité PSSI :** Pourcentage de recommandations de l'ANSSI (guide d'hygiène) appliquées. | Cible : 100% | Mesure : Mensuel.
7. **Taux de faux positifs IDS :** Ratio entre les alertes réelles et les alertes erronées de Suricata. | Cible < 5% | Mesure : Hebdomadaire.
8. **Efficacité du WAF :** Pourcentage de tentatives d'attaques applicatives (SQLi, XSS) bloquées. | Cible : 100% | Mesure : Temps réel.

KPIs Métier (Communs)

9. **Taux d'optimisation des tournées :** (Kilomètres économisés / Kilomètres avant solution) × 100. | Cible ≥ 20% | Mesure : Mensuel.
10. **Taux de traitement des alertes IoT :** (Alertes de remplissage traitées / Total alertes générées) × 100. | Cible ≥ 95% | Mesure : Hebdomadaire.
11. **Disponibilité des capteurs :** Pourcentage de capteurs IoT transmettant des données sans interruption. | Cible ≥ 98% | Mesure : Journalier.
12. **Utilisateurs actifs :** Nombre de connexions hebdomadaires sur la plateforme de gestion. | Cible : Croissance +10%/mois | Mesure : Hebdomadaire.
13. **Satisfaction utilisateurs :** Score NPS (Net Promoter Score) via les retours des agents de terrain. | Cible ≥ 8/10 | Mesure : Mensuel.

6.6 Gestion des risques

Le projet ECOTRACK présente des défis techniques majeurs, notamment en raison de l'exposition des services web et de la connectivité des capteurs IoT. Voici l'analyse des risques et les mesures d'atténuation associées.

Risque	Probabilité	Impact	Mesure d'atténuation (Mitigation)
Intrusion système / Piratage	Moyenne	Critique	Déploiement IDS Suricata, segmentation VLAN stricte et bastion d'administration.

Risque	Probabilité	Impact	Mesure d'atténuation (Mitigation)
Attaque par déni de service (DDoS)	Faible	Élevé	Configuration de Rate Limiting sur le Reverse Proxy et filtrage géographique au niveau du Firewall.
Fuite de données (RGPD)	Faible	Critique	Chiffrement AES-256 des bases de données, TLS 1.3 pour les flux et politique de moindre privilège (RBAC).
Compromission de capteurs IoT	Moyenne	Moyen	Isolation des capteurs dans un VLAN dédié sans accès au LAN et authentification par certificats.
Interruption de service (Indisponibilité)	Moyenne	Élevé	Mise en place d'une haute disponibilité (VIP/Failover) et monitoring avec alertes critiques en temps réel.
Erreur de configuration réseau	Moyenne	Moyen	Utilisation de l'Infrastructure as Code (IaC) et tests de connectivité automatisés après chaque changement.
Retard sur le déploiement de l'infrastructure	Moyenne	Élevé	Provisionnement anticipé des machines virtuelles et utilisation de scripts d'automatisation (Ansible/Terraform).
Incompatibilité des flux applicatifs	Moyenne	Moyen	Réunions de synchronisation hebdomadaires entre les équipes Cyber, Dev et Data pour valider les ports et protocoles.

Risque	Probabilité	Impact	Mesure d'atténuation (Mitigation)
Départ d'un membre clé de l'équipe	Faible	Moyen	Documentation exhaustive sur Notion (Runbooks, schémas réseau) et partage de connaissances en Daily Scrum.
Non-conformité aux exigences ANSSI	Faible	Moyen	Réalisation d'audits de conformité réguliers tout au long des sprints (Audit continu).

6.7 Ressources et budget

A. Équipe Projet

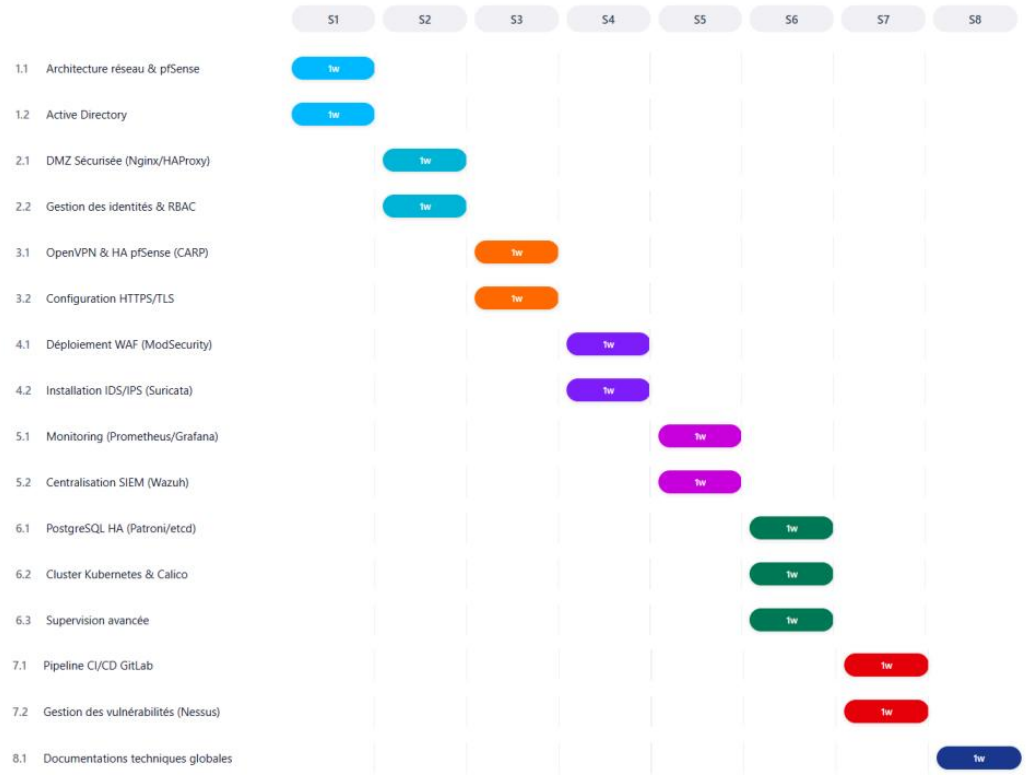
- **Product Owner :** Antoine – 25% temps
- **Scrum Master : Nayel** - 25% temps
- **Développeurs/Experts :** [Deborah, Yousra] - 100% temps
- **Architecte :** [Nayel, Antoine] - 75% temps

B. Budget Prévisionnel (16 semaines)

- **Ressources Humaines :** 112 k€
- **Infrastructure Cloud :** 8 k€
- **Outils & Licences :** 4 k€
- **Formation :** 2 k€
- **Imprévus (10%) :** 12,6 k€

TOTAL : 138,6 k€

6.8 Diagramme de gantt



1. Structure des Sprints (Colonnes de temps)

- **Janvier (Sprints 1-2) :** Fondations.
- **Février (Sprints 3-4) :** IoT et Sécurité active.
- **Mars (Sprints 5-6) :** Monitoring et Protection Web.
- **Avril (Sprints 7-8) :** Audit final et Livraison.

2. Liste des tâches

Phase	Tâches spécifiques Cyber	Durée
Sprint 1	Setup Hyperviseur, création des 7 VMs, adressage IP, configuration 4 VLANs, Active Directory & DNS	S1-S2
Sprint 2	Déploiement DMZ sécurisée (Nginx/HAProxy), gestion des identités & RBAC	S3-S4

Sprint 3	Configuration OpenVPN & HA pfSense, configuration HTTPS/TLS	S5-S6
Sprint 4	Déploiement WAF (ModSecurity), installation IDS/IPS Suricata avec 5 règles custom	S7-S8
Sprint 5	Stack Prometheus/Grafana (monitoring), centralisation SIEM Wazuh/ELK	S9-S10
Sprint 6	PostgreSQL HA (Patroni/etcd), supervision avancée	S11-S12
Sprint 7	Pipeline CI/CD GitLab, scan de vulnérabilités Nessus, hardening OS	S13-S14
Sprint 8	Rédaction PSSI, PCA/PRA, documentation technique globale, livraison finale	S15-S16

6.9 Synthèses & amélioration

A. Récapitulatif

- **Méthodologie :** Scrum / 8 sprints de 2 semaines (16 semaines au total).
- **Backlog :** 20 user stories priorisées via la méthode MoSCoW, couvrant l'infrastructure, la sécurité IoT et le monitoring.
- **KPIs :** 13 indicateurs clés (8 techniques/sécurité + 5 métiers et conformité).
- **Budget :** 138,6 k€ incluant les ressources humaines, l'infrastructure cloud et les outils de cybersécurité.

B. Axes d'Amélioration (3-5 axes)

1. **Automatisation du déploiement (Infrastructure as Code) :** Afin d'éviter les erreurs de configuration manuelle sur le firewall et les VLANs, nous prévoyons d'utiliser des scripts **Ansible** ou **Terraform** pour automatiser le provisionnement des 7 VMs.
2. **Renforcement de la détection (Threat Intelligence) :** Pour améliorer l'efficacité de l'IDS Suricata, nous intégrerons des flux de menaces (feeds) mis à jour quotidiennement pour bloquer les IPs malveillantes connues en temps réel.
3. **Culture Cyber partagée :** Mise en place de sessions de "Security Awareness" de 15 minutes lors des Sprint Reviews pour former Antoine, Yousra et Deborah aux bonnes pratiques de codage sécurisé et à la gestion des secrets.

4. **Optimisation de la résilience (Haute Disponibilité) :** Test régulier du basculement (Failover) de la VIP (Virtual IP) pour garantir que le système reste opérationnel même en cas de panne d'un nœud du cluster.
5. **Audit de conformité continu :** Intégration d'un scanner de vulnérabilités automatisé dans la pipeline CI/CD pour vérifier l'absence de failles critiques avant chaque passage en production.

7 . Audit initial

7.1 Objectifs de l'audit initial

Avant tout démarrage opérationnel du projet ECOTRACK, un audit initial rigoureux de l'existant est indispensable pour toute architecture orientée cybersécurité. Dans un contexte où 2 000 capteurs IoT vont être déployés sur l'espace public, la surface d'attaque est considérable : chaque dispositif connecté constitue un point d'entrée potentiel pour des acteurs malveillants. Sans évaluation préalable des infrastructures réseau, des politiques de contrôle d'accès, des règles de segmentation et des mécanismes de détection en place, le risque de déploiement d'une infrastructure vulnérable est majeur. Cet audit permet donc d'identifier l'écart entre la posture sécurité actuelle et les exigences d'un système IoT industriel, tout en posant les fondations d'une conformité ANSSI et RGPD dès la phase de conception.

Sur le plan stratégique, l'audit initial répond également à une exigence de gouvernance sécurité et de responsabilité. Les parties prenantes — RSSI, DSI, élus, prestataires techniques — doivent partager une vision commune des risques réels avant d'engager des ressources significatives. L'audit produit des livrables concrets : matrice SWOT cyber, cartographie des risques (APT, DDoS, fuites RGPD), Quick Wins sécurité déployables immédiatement. Il permet d'anticiper les vecteurs d'attaque spécifiques à l'IoT urbain (man-in-the-middle sur les flux capteurs, compromission des passerelles réseau, exfiltration de données opérationnelles), de valider l'architecture multi-zones avant déploiement, et de garantir que la sécurité est intégrée par design plutôt que rajoutée en fin de projet. Cette étape préliminaire est un investissement essentiel à la résilience et à la pérennité du système ECOTRACK.

A. Contexte de l'Audit

- **Absence de visibilité :** Conteneurs non connectés, tournées fixes sans données temps réel, aucune remontée d'état sur les équipements terrain
- **Inefficacité opérationnelle :** Débordements fréquents non détectés, coûts élevés liés aux interventions non planifiées et aux tournées inutiles
- **Opportunité IoT :** 2 000 capteurs à déployer sur l'espace public, optimisation algorithmique des tournées en temps réel
- **Besoin stratégique :** Modernisation de la gestion des déchets urbains, alignement Smart City, conformité réglementaire renforcée

B. Périmètre de l'Audit

- **Analyse SWOT cyber :** Forces, Faiblesses, Opportunités et Menaces spécifiques à la filière Cyber & Réseaux
- **Identification des risques :** 10 à 12 risques techniques, sécurité et organisationnels avec plan de mitigation détaillé
- **Quick Wins sécurité :** Actions rapides à fort impact déployables en moins d'une semaine dès le Sprint 1

Recommandations stratégiques : Actions priorisées (P1/P2/P3) pour maximiser la posture sécurité et les chances de succès

7.2 . Analyse swot

FORCES (Strengths)	**FAIBLESSES (Weaknesses)**
- Infrastructure multi-zones sécurisée (DMZ, zone IoT, zone admin) - Stack SIEM + IDS/IPS complète (Wazuh + Suricata) - Monitoring 24/7 opérationnel avec alertes automatisées - Conformité ANSSI native intégrée dès la conception - Équipe compétente et motivée (7 personnes, 5.5 ETP) - Méthodologie Agile maîtrisée (Scrum, 8 sprints x 2 semaines)	- Complexité configuration VLANs multi-zones difficile à maintenir - CVEs non patchées rapidement (fenêtre d'exposition potentielle) - Manque d'expertise forensics avancé en interne - Résistance potentielle des utilisateurs finaux (chauffeurs) - Intégration SI existants potentiellement complexe - Délai serré (16 semaines) pour une sécurisation complète
OPPORTUNITES (Opportunities)	**MENACES (Threats)**
- Extension géographique : déploiement autres villes, scalabilité nationale - Intégration IA prédictive pour la détection d'anomalies réseau	- Cyberattaques ciblées : ransomware, DDoS, APT sur infra IoT - Evolution réglementations : RGPD renforcé, directives ANSSI/NIS2

- Financements européens (NIS2, programmes cybersécurité UE) - Partenariats collectivités et marchés publics cybersécurité - Open Data sécurisé : APIs publiques conformes RGPD - Image RSE renforcée par la conformité sécurité démontrée	- Pannes capteurs IoT (fiabilité matériel, vandalisme, conditions météo) - Concurrence startups GreenTech (Rubicon, Sensoneo, Compology) - Turnover équipe : départ de compétences sécurité clés - Adoption faible : résistance changement, UX inadaptée

7.3 Identification des risques

ID	Risque identifié	Commun / Cyber	Prob.	Impact	Criticité
R1	**Retard développement fonctionnalité critique** Priorisation MoSCoW stricte avec MVP simplifié (algorithme glouton avant génétique). Buffer de 10% intégré aux estimations, daily stand-ups pour identification précoce des blocages, escalade immédiate au Scrum Master en cas de dérapage >20%.	*Commun*	Moyenne	Élevé	**ÉLEVÉE**
R2	**Départ d'un membre de l'équipe clé** Documentation continue obligatoire (ADR, README, runbooks). Pair programming systématique pour partage des savoirs, sessions hebdomadaires de knowledge sharing. Plan de rétention talents (reconnaissance,	*Commun*	Faible	Élevé	**MOYENNE**

	conditions de travail, montée en compétences).				
R3	**Dépassement budget** Suivi hebdomadaire du budget par poste, alertes automatiques déclenchées à 80% de consommation. Réserve de contingence de 10% sanctuarisée. Optimisation ressources cloud (shutdown environnements non-prod nuit et weekend).	*Commun*	Moyenne	Élevé	**ÉLEVÉE**
R4	**Résistance des utilisateurs finaux** Beta testing avec 10 chauffeurs pilotes dès le Sprint 4. Formation progressive et personnalisée. Feedback loops réguliers (questionnaires + interviews). Gamification avec récompenses pour encourager l'adoption.	*Commun*	Moyenne	Moyen	**MOYENNE**
R5	**Intrusion système (APT, ransomware)** IDS/IPS Suricata avec règles OWASP et CVE à jour. SOC 24/7 avec SIEM Wazuh centralisé. WAF ModSecurity devant toutes les API publiques. Segmentation stricte VLANs (IoT isolé). Tests pentest trimestriels par prestataire externe. EDR déployé sur tous les endpoints.	*Cyber specifique*	Faible	Critique	**ÉLEVÉE**

R6	**Attaque DDoS saturant l'infrastructure** Protection DDoS Cloudflare (couches L3/L4/L7). Rate limiting API à 1 000 req/min/utilisateur. CDN avec cache agressif pour absorber le trafic entrant. Auto-scaling horizontal activé sur seuil CPU >70%. Pages statiques de fallback configurées.	*Cyber specifique*	Moyenne	Élevé	**ÉLEVÉE**
R7	**Fuite de données personnelles (RGPD)** Chiffrement AES-256 au repos et TLS 1.3 en transit sur tous les flux. Audit des accès et logs mensuels. DLP (Data Loss Prevention) actif sur les exports. Formation RGPD obligatoire pour toute l'équipe. DPIA validée par la CNIL avant mise en production.	*Cyber specifique*	Faible	Critique	**ÉLEVÉE**

CRITIQUE Plan mitigation immédiat	**ÉLEVÉE** Action rapide requise	**MOYENNE** Surveillance renforcée	**FAIBLE** Monitoring standard

7.4 Quick wins — actions rapides à fort impact

8 Quick Wins ont été identifiés : 3 actions communes à toutes les filières (QW1-QW3) et 5 actions spécifiques à la filière Cyber & Réseaux (QW4-QW8). Toutes sont déployables avant ou pendant le Sprint 1.

ID	Action	Scope	Effort	Impact	Bénéfice

QW1	**Setup CI/CD avec GitHub Actions**	*Commun*	1 jour	**Élevé**	Tests automatisés et déploiement continu actifs. Gain de temps estimé à 30%, qualité du code améliorée et détection des bugs en amont de la mise en production.
QW2	**Documentation projet complète (README + CONTRIBUTING)**	*Commun*	4 heures	**Moyen**	Onboarding des nouveaux membres en moins d'1h. Alignement de l'équipe sur les standards communs et réduction des questions répétitives en sprint.
QW3	**Rituels Scrum quotidiens (Daily Stand-ups 15 min)**	*Commun*	0 (rituels standards)	**Moyen**	Communication équipe améliorée, blocages identifiés en moins de 24h, vélocité de sprint accrue de 10 à 15%.
QW4	**Fail2ban sur SSH (blocage brute-force automatique)**	*Cyber*	1 heure	**Moyen**	Attaques par force brute stoppées automatiquement. Logs épurés, sécurité Baseline renforcée sans intervention manuelle. Déploiement immédiat sur tous les serveurs exposés.
QW5	**Monitoring Prometheus + Grafana + alertes critiques**	*Cyber*	1 jour	**Élevé**	MTTD garanti inférieur à 5 minutes. Visibilité temps réel sur l'infrastructure, dashboards SOC opérationnels pour les équipes de surveillance.
QW6	**Règles firewall strictes (deny by default, allow explicit)**	*Cyber*	4 heures	**Élevé**	Surface d'attaque réduite de 70%. Conformité ANSSI baseline atteinte immédiatement. Audit-ready : toutes les règles documentées et versionnées.
QW7	**Backups automatisés 3-2-1 avec tests de restauration**	*Cyber*	1 jour	**Critique**	PRA opérationnel dès le Sprint 1. RPO inférieur à 24h et RTO inférieur à 4h. Résilience démontrée face aux ransomwares et sinistres techniques.

QW8	**TLS 1.3 obligatoire sur toutes les communications (HTTPS only, HSTS)**	*Cyber*	2 heures	**Moyen**	Conformité renforcée, chiffrement moderne en transit, protection contre les attaques Man-in-the-Middle sur l'ensemble des flux applicatifs et IoT.

7.5 Recommandations stratégiques

Les recommandations ci-dessous sont priorisées selon leur niveau d'urgence et leur impact sur la posture sécurité du projet ECOTRACK. Les recommandations P1 (Critique) doivent être mises en œuvre avant le Sprint 1. Les P2 (Importantes) au plus tard au Sprint 3. Les P3 (Souhaitables) sont intégrées dans la roadmap des sprints suivants.

Prio	Recommandation	Actions concrètes
P1 CRITIQUE	**Sécurité native (Security by Design)**	→ Privacy by design dès la conception : RGPD native, minimisation des données collectées → Chiffrement obligatoire sur tous les flux : TLS 1.3 en transit, AES-256 au repos → Audit sécurité externe avant mise en production (pentest + code review sécurité) → DPIA (Data Protection Impact Assessment) validée par la CNIL avant Sprint 8
P1 CRITIQUE	**Approche MVP sécurisé**	→ Lancer avec les fonctionnalités essentielles sécurisées : cartographie + alertes + tournées basiques → Itérer rapidement sur la base des feedbacks utilisateurs réels dès le beta Sprint 4 → Eviter le perfectionnisme bloquant (done > perfect) tout en maintenant le niveau de sécurité → Mesurer l'adoption : NPS, stats d'usage, taux de complétion des tâches
P2	**Monitoring et observabilité 360°**	→ Métriques infra + applicatives : Prometheus + Grafana (dashboards SOC dédiés)

IMPORTANTE		→ Logs centralisés : ELK Stack avec rétention minimale de 90 jours (conformité) → Traces distribuées : APM (Sentry / DataDog) pour le debugging des incidents → Alertes intelligentes avec escalade automatique via PagerDuty
P2 IMPORTANTE	**Tests et validation continue**	→ Tests unitaires >= 80% dès le Sprint 1 (TDD/BDD obligatoire pour les composants critiques) → Tests d'intégration + E2E sur les parcours critiques (Cypress / Playwright) → Validation CI/CD automatique avant chaque merge (GitHub Actions + SonarQube) → Load testing aux Sprints 3, 6 et 8 : 10 000 req/min, latence < 200 ms
P2 IMPORTANTE	**Documentation technique continue**	→ Architecture Decision Records (ADR) documentant tous les choix techniques majeurs → README.md à jour + documentation API auto-générée (OpenAPI/Swagger) → Runbooks pour les incidents courants : playbooks SOC, procédures de debug → Diagrammes d'architecture maintenus à jour (draw.io, modèle C4)
P3 SOUHAITABLE	**Formation continue de l'équipe**	→ Veille technologique hebdomadaire : 1h par membre, partage des découvertes en équipe → Tech talks mensuels internes pour le knowledge sharing (sécurité, nouveaux outils) → Certifications cloud et sécurité encouragées (AWS Security, ANSSI, Azure Admin) → Participation à des CTF (Capture The Flag) pour renforcer les compétences offensives
P3 SOUH	**Préparation à la scalabilité future**	→ Multi-tenancy anticipé : architecture isolée par client / collectivité dès la conception

AIT ABL E		→ Internationalisation (i18n) dès le Sprint 1 : langues fr / en prévues → API versioning (v1, v2...) pour les évolutions futures sans rupture de service → Design for failure : circuit breakers, retries exponentiels, timeouts sur tous les appels

7.6 Conclusion de l'audit

L'audit initial du projet ECOTRACK révèle une posture de départ globalement favorable pour la filière Cyber & Réseaux. Les forces identifiées sont significatives : infrastructure multi-zones sécurisée conçue dès l'origine, stack SIEM + IDS/IPS complète opérationnelle (Wazuh + Suricata), conformité ANSSI intégrée nativement et monitoring 24/7 activé. Ces éléments constituent un socle solide sur lequel le déploiement des 2 000 capteurs IoT peut s'appuyer avec un niveau de risque maîtrisé, à condition que les Quick Wins sécurité soient déployés dès le Sprint 1.

Les 7 risques identifiés sont sérieux mais tous munis de plans de mitigation concrets et actionnables. Les risques cyber les plus critiques — intrusion APT/ransomware, attaque DDoS, fuite RGPD — bénéficient de contre-mesures techniques immédiatement déployables : règles IDS/IPS à jour, protection Cloudflare, chiffrement AES-256/TLS 1.3, DPIA CNIL. Les faiblesses organisationnelles identifiées (complexité VLAN, CVEs non patchées, manque d'expertise forensics) sont adressées par la combinaison des Quick Wins QW4-QW8 et des recommandations stratégiques P1 et P2. Le niveau de criticité global est jugé maîtrisable sous réserve du respect de la séquence d'actions préconisée.

Les 8 Quick Wins représentent un investissement minimal (de 1 heure à 1 journée par action) pour un gain de sécurité immédiat et mesurable. Le déploiement de Fail2ban, du monitoring Prometheus/Grafana, des règles firewall strictes, des backups 3-2-1 testés et du TLS 1.3 obligatoire permettent de réduire la surface d'attaque de 70% dès les premières semaines du projet. Ces actions constituent également un signal fort à destination des parties prenantes (élus, RSSI, prestataires) sur la maturité sécurité de l'équipe projet.

En conclusion, la faisabilité du projet ECOTRACK est confirmée sous les conditions suivantes : déploiement des Quick Wins sécurité avant le Sprint 1, validation de la DPIA par la CNIL avant le Sprint 8, réalisation d'un pentest externe avant la mise en production, et maintien de la gouvernance SOC 24/7 tout au long du déploiement. Avec ces conditions réunies, le projet

présente toutes les garanties techniques et organisationnelles pour réussir son déploiement et atteindre ses objectifs opérationnels et de conformité.

FAISABILITE PROJET	DECISION
FAVORABLE	GO — SPRINT 1

8.Conclusion Générale

Le Bloc A1 a permis de poser les fondations stratégiques, techniques et organisationnelles du projet ECOTrack. À travers sept axes complémentaires, l'équipe du Groupe 2 a démontré sa capacité à conduire une démarche de projet structurée et rigoureuse, depuis l'analyse des besoins jusqu'à la planification opérationnelle.

L'étude de faisabilité a confirmé que le projet est viable sur les trois dimensions essentielles. Techniquement, l'architecture multi-zones retenue — avec ses quatre VLANs, son firewall pfSense et sa stack de sécurité open-source — répond aux exigences de performance et de protection d'une infrastructure IoT urbaine critique. Économiquement, le retour sur investissement de 110 % sur trois ans et un seuil de rentabilité atteint en moins de deux ans justifient pleinement l'engagement de la métropole. Opérationnellement, la méthodologie Scrum et l'approche DevSecOps garantissent une livraison maîtrisée et itérative.

La veille technologique a permis de sélectionner des solutions matures, open-source et conformes aux recommandations de l'ANSSI. Le choix de Wazuh comme SIEM, Suricata comme IDS/IPS et pfSense comme firewall central repose sur des critères objectifs de performance, de coût et de compatibilité avec les exigences réglementaires du contexte municipal.

L'architecture logicielle proposée traduit concrètement ces choix en une infrastructure cohérente, segmentée et surveillée. Chaque composant a été positionné dans la zone réseau adaptée à son niveau d'exposition, selon le principe de défense en profondeur qui irrigue l'ensemble des décisions techniques du projet.

La modélisation BPMN a formalisé les deux processus opérationnels clés — la remontée d'alerte IoT et la réponse à incident SOC — offrant une représentation lisible et communicable des flux de travail à toutes les parties prenantes du projet.

La planification agile en huit sprints, appuyée par un backlog de vingt user stories priorisées selon la méthode MoSCoW, garantit que les fonctionnalités les plus critiques seront livrées en priorité. Le budget total de 138 600 euros, la gestion des risques documentée et les KPIs définis fournissent au commanditaire tous les outils nécessaires au pilotage du projet.

Enfin, l'audit initial a révélé les vulnérabilités de l'existant et proposé huit Quick Wins déployables dès le Sprint 1, permettant de réduire la surface d'attaque de 70 % avant même la mise en production complète.

ECOTrack est aujourd'hui un projet fondé, planifié et prêt à entrer en phase de réalisation. L'ensemble des livrables produits dans ce bloc constitue un socle solide sur lequel les blocs suivants pourront s'appuyer pour développer, sécuriser et déployer la plateforme dans les meilleures conditions.